

サンプル問題 情報セキュリティマネジメント試験

科目 A・B 中日英对照学习版

原题来源：IPA サンプル問題 | 本PDF为学习辅助：词汇对照 + 中文题意/选项翻译

不含图表的题：原文 → 中文题意 → 单词表 → 选项对照

含图表/案例的题：先单词表 → 再贴原题完整页面（含表格）→ 再给完整中文意思

問1 / 问题 1

■ 原文（日文）

JIS Q 27001:2014（情報セキュリティマネジメントシステム - 要求事項）において、リスクを受容するプロセスに求められるものはどれか。

■ 中文题意

依据 JIS Q 27001:2014（信息安全管理体系统 - 要求事项），对于“接受风险”这一过程所要求的内容是下列哪一项？

■ 重点单词（日文 → English → 中文）

日文	English	中文
リスクを受容する	accept risk	接受风险
プロセス	process	过程
求められる	be required	被要求
リスク所有者	risk owner	风险责任人
承認する	approve	批准
監視	monitoring	监视
レビュー	review	评审
対象外	excluded from	排除在外
リスク分析	risk analysis	风险分析
リスク対応	risk treatment	风险应对
決定する	decide	决定

■ 选项对照

ア. 受容するリスクについては、リスク所有者が承認すること

→ 对于要接受的风险，应由风险责任人予以批准。

イ. 受容するリスクを監視やレビューの対象外とすること

→ 将已接受的风险排除在监视和评审对象之外。（错误，接受的风险仍需持续监视与评审）

ウ. リスクの受容は、リスク分析前に行うこと

→ 风险的接受应在风险分析之前进行。（错误，必须先分析评价风险，再决定是否接受）

エ. リスクを受容するかどうかは、リスク対応後に決定すること

→ 是否接受风险，应在完成风险应对之后再决定。（错误，“保有/接受风险”本身就是风险应对方式之一，并非应对完成后才决定）

問2 / 问题 2

■ 原文 (日文)

退職する従業員による不正を防ぐための対策のうち、IPA「組織における内部不正防止ガイドライン（第5版）」に照らして、適切なものはどれか。

■ 中文题意

在防止离职员工不正行为的对策中，依据 IPA《组织内部不正行为防止指南（第5版）》，恰当的是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
退職する従業員	resigning / departing employee	离职员工
内部不正	internal fraud	内部不正行为
内部不正防止ガイドライン	Guidelines for Preventing Internal Fraud	内部不正行为防止指南
秘密保持誓約書	non-disclosure pledge	保密誓约书
客観的に特定できない	cannot be objectively identified	无法被客观识别
競業避止義務契約	non-compete agreement	竞业禁止协议
職業選択の自由	freedom of occupation choice	职业选择自由
利用者ID	user ID	用户 ID
権限	privilege	权限
持出し	taking out / removal	带出、拿走
監視を強化する	strengthen monitoring	加强监视

■ 选项对照

ア. 在職中に知り得た重要情報を退職後に公開しないように、退職予定者に提出させる秘密保持誓約書には、秘密保持の対象を明示せず、重要情報を客観的に特定できないようにしておく。

→ 为防止在职期间获知的重要信息在离职后被公开，要求拟离职者提交的保密誓约书中不明确保密对象，使重要信息无法被客观认定。（错误，不明确保密对象会导致誓约书无法有效执行）

イ. 退職後、同業他社に転職して重要情報を漏らすということがないように、職業選択の自由を行使しないことを明記した上で、具体的な範囲を設定しない包括的な競業避止義務契約を入社時に締結する。

→ 为防止离职后跳槽至同行泄露重要信息，在入职时签订载明放弃行使职业选择自由、且不设定具体范围的全面性竞业禁止协议。（错误，过度限制职业选择自由的竞业协议可能因违反公序良俗而无效）

ウ. 退職者による重要情報の持出しなどの不正行為を調査できるように、従業員に付与した利用者IDや権限は退職後も有効にしておく。

→ 为便于调查离职人员带走重要信息等不正行为，将员工的用户 ID 及权限在离职后继续保留有效。（错误，离职后应立即停用账号权限，否则本身就是重大安全隐患）

エ. 退職間際に重要情報の不正な持出しが行われやすいので、退職予定者に対する重要情報へのアクセスや媒体の持出しの監視を強化する。

→ 由于临近离职时容易发生重要信息的违规带出，因此加强对拟离职人员访问重要信息及带出存储介质的监视。

問3 / 问题 3

■ 原文 (日文)

JIS Q 27000:2019 (情報セキュリティマネジメントシステム - 用語) において、不適合が発生した場合にその原因を除去し、再発を防止するためのものとして定義されているものはどれか。

■ 中文题意

依据 JIS Q 27000:2019 (信息安全管理体系统 - 术语)，当发生不符合项时，为消除其原因并防止再发生而定义的措施是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
不適合	nonconformity	不符合项
原因を除去する	eliminate the cause	消除原因
再発を防止する	prevent recurrence	防止再次发生
継続的改善	continual improvement	持续改进
修正	correction	纠正
是正処置	corrective action	纠正措施
リスクアセスメント	risk assessment	风险评估

■ 选项对照

ア. 継続的改善

→ 持续改进 (错误，指整体体系持续优化的活动，并非针对具体不符合项原因的措施)

イ. 修正

→ 纠正 (错误，修正仅是消除已发现的不符合项本身，不涉及消除原因、防止再发)

ウ. 是正処置

→ 纠正措施

エ. リスクアセスメント

→ 风险评估 (错误，指识别、分析和评价风险的过程)

問4 / 问题 4

■ 原文 (日文)

JIS Q 27002:2014 (情報セキュリティ管理策の実践のための規範) の“サポートユーティリティ”に関する例示に基づいて、サポートユーティリティと判断されるものはどれか。

■ 中文题意

依据 JIS Q

27002:2014 (信息安全管理措施实施细则) 中关于“支持性设施”的示例，可判定为支持性设施的是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
サポートユーティリティ	supporting utilities	支持性设施
例示	examples	示例
判断される	be judged as	被判定为
サーバ室の空調	server room air conditioning	服务器机房空调
保守契約	maintenance contract	维护合同
特権管理プログラム	privileged access management program	特权管理程序
ネットワーク管理者	network administrator	网络管理员

■ 选项对照

ア. サーバ室の空調

→ 服务器机房的空调设备。

イ. サーバの保守契約

→ 服务器的维护合同。(错误，属于合同/服务协议，非物理支持设施)

ウ. 特権管理プログラム

→ 特权管理程序。(错误，属于访问控制相关软件)

エ. ネットワーク管理者

→ 网络管理员。(错误，属于人员，不是设施)

問5 / 问题 5

■ 原文 (日文)

JIS Q 27000:2019 (情報セキュリティマネジメントシステム - 用語) における“リスクレベル”の定義はどれか。

■ 中文题意

依据 JIS Q 27000:2019 (信息安全管理体系统 - 术语) , “风险等级 (risk level) ”的定义是下列哪一项 ?

■ 重点单词 (日文 → English → 中文)

日文	English	中文
リスクレベル	risk level	风险等级
定義	definition	定义
脅威	threat	威胁
付け込まれる	be exploited	被利用、被趁虚而入
資産	asset	资产
管理策	control	管理措施
弱点	weakness	弱点
結果	consequence	后果
起こりやすさ	likelihood	发生的可能性
組合せ	combination	组合
優先順位	priority	优先级
目安とする条件	benchmark condition	作为参照标准的条件

■ 选项对照

ア. 脅威によって付け込まれる可能性のある , 資産又は管理策の弱点

→ 可能被威胁所利用的资产或管理措施上的弱点。(错误 , 这是“脆弱性”的定义)

イ. 結果とその起こりやすさの組合せとして表現される , リスクの大きさ

→ 以后果及其发生可能性的组合形式来表现的风险大小。

ウ. 対応すべきリスクに付与する優先順位

→ 赋予应予应对的风险的优先级。(错误 , 这更接近“风险优先级排序”的概念 , 而非风险等级本身的定义)

エ. リスクの重大性を評価するために目安とする条件

→ 为评价风险严重性而作为参照标准的条件。(错误 , 这是“风险评价准则”的定义)

問6 / 问题 6

■ 原文 (日文)

サイバーセキュリティ基本法に基づき、内閣にサイバーセキュリティ戦略本部が設置されたのと同時に、内閣官房に設置された組織はどれか。

■ 中文题意

依据《网络安全基本法》，与内阁设立网络安全战略总部同时，在内阁官房设立的组织是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
サイバーセキュリティ基本法	Basic Act on Cybersecurity	网络安全基本法
内閣	Cabinet	内阁
サイバーセキュリティ戦略本部	Cybersecurity Strategy Headquarters	网络安全战略总部
設置される	be established	被设立
内閣官房	Cabinet Secretariat	内阁官房
IPA	Information-technology Promotion Agency	信息处理推进机构 (IPA)
JIPDEC	Japan Institute for Promotion of Digital Economy and Community	日本信息处理开发协会
JPCERT/CC	JPCERT Coordination Center	JPCERT 协调中心
NISC	National center of Incident readiness and Strategy for Cybersecurity	网络安全中心 (NISC)

■ 选项对照

ア. IPA

→ 信息处理推进机构 (IPA) 。 (错误，为独立行政法人，非内阁官房设立机构)

イ. JIPDEC

→ 日本信息处理开发协会。 (错误，为一般财团法人)

ウ. JPCERT/CC

→ JPCERT 协调中心。 (错误，为民间组织)

エ. NISC

→ 内阁网络安全中心 (NISC) 。

問7 / 问题 7

■ 原文 (日文)

CRYPTRECの役割として、適切なものはどれか。

■ 中文题意

CRYPTREC (密码技术评价委员会) 的作用，恰当的是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
CRYPTREC	CRYPTREC	CRYPTREC (密码技术评价委员会)
役割	role	作用
外国為替及び外国貿易法	Foreign Exchange and Foreign Trade Act	外汇及外贸法
暗号装置	cryptographic device	加密设备
輸出許可申請	export permit application	出口许可申请
審査，承認する	examine and approve	审查并批准
政府調達	government procurement	政府采购
評価，認証する	evaluate and certify	评估并认证
電子政府	e-Government	电子政务
暗号技術	cryptographic technology	密码技术
安全性	security	安全性
監視，検知する	monitor and detect	监视并检测

■ 选项对照

ア. 外国為替及び外国貿易法で規制されている暗号装置の輸出許可申請を審査，承認する。

→ 审查并批准受外汇及外贸法管制的加密设备出口许可申请。(错误，属于经济产业省的管制职责)

イ. 政府調達においてIT関連製品のセキュリティ機能の適切性を評価，認証する。

→ 在政府采购中评估并认证 IT 相关产品安全功能的适当性。(错误，这是 ISO/IEC 15408 (CC认证) 相关制度的职责)

ウ. 電子政府での利用を推奨する暗号技術の安全性を評価，監視する。

→ 评估并监视推荐用于电子政务的密码技术的安全性。

エ. 民間企業のサーバに対するセキュリティ攻撃を監視，検知する。

→ 监视并检测针对民营企业服务器的安全攻击。(错误，此为 JPCERT/CC 等机构的职责)

問8 / 问题 8

■ 原文 (日文)

緊急事態を装って組織内部の人間からパスワードや機密情報を入手する不正な行為は、どれに分類されるか。

■ 中文题意

伪装成紧急事态，从组织内部人员处获取密码或机密信息的不正当行为，属于下列哪一种分类？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
緊急事態を装う	disguise as an emergency	伪装成紧急事态
組織内部の人間	person inside the organization	组织内部人员
不正な行為	fraudulent act	不正行为
ソーシャルエンジニアリング	social engineering	社会工程学
トロイの木馬	Trojan horse	特洛伊木马
踏み台攻撃	stepping-stone attack	跳板攻击
ブルートフォース攻撃	brute-force attack	暴力破解攻击

■ 选项对照

ア. ソーシャルエンジニアリング

→ 社会工程学。

イ. トロイの木馬

→ 特洛伊木马。(错误，指伪装成正常程序的恶意软件)

ウ. 踏み台攻撃

→ 跳板攻击。(错误，指利用被入侵的第三方系统作为跳板发起进一步攻击)

エ. ブルートフォース攻撃

→ 暴力破解攻击。(错误，指通过穷举方式尝试破解密码)

問9 / 问题 9

■ 原文 (日文)

A社では現在，インターネット上のWebサイトを内部ネットワークのPC上のWebブラウザから参照している。新たなシステムを導入し，DMZ上に用意したVDI (Virtual Desktop Infrastructure) サーバにPCからログインし，インターネット上のWebサイトをVDIサーバ上の仮想デスクトップのWebブラウザから参照するように変更する。この変更によって期待できるセキュリティ上の効果はどれか。

■ 中文题意

A 公司目前是从内部网络的 PC 上的 Web 浏览器直接访问互联网上的网站。现引入新系统，改为从 PC 登录到设置在 DMZ 上的 VDI (虚拟桌面基础设施) 服务器，通过 VDI 服务器上虚拟桌面的 Web 浏览器来访问互联网网站。此项变更所能期待的安全效果是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
VDI	Virtual Desktop Infrastructure	虚拟桌面基础设施 (VDI)
DMZ	demilitarized zone	非军事区 (DMZ)
仮想デスクトップ	virtual desktop	虚拟桌面
期待できる効果	expected effect	预期效果
マルウェアのダウンロード	malware download	恶意软件下载
MITB攻撃	man-in-the-browser attack	浏览器中间人攻击 (MITB)
送信データの改ざん	tampering with transmitted data	篡改发送数据
ボットに感染する	become infected by a bot	感染僵尸程序
C&Cサーバ	command and control server	C&C 服务器
感染するのを防ぐ	prevent infection	防止感染

■ 选项对照

ア. インターネット上のWebサイトから，内部ネットワークのPCへのマルウェアのダウンロードを防ぐ。

→ 防止从互联网上的网站向内部网络的 PC 下载恶意软件。

イ. インターネット上のWebサイト利用時に，MITB攻撃による送信データの改ざんを防ぐ。

→ 在使用互联网网站时，防止 MITB 攻击对发送数据的篡改。(错误，MITB 攻击针对浏览器本身，将浏览操作转移到虚拟桌面并不能从根本上防止该类攻击)

ウ. 内部ネットワークのPC及び仮想デスクトップのOSがボットに感染しなくなり，C&Cサーバにコントロールされることを防ぐ。

→ 使内部网络 PC 及虚拟桌面的操作系统都不再感染僵尸程序，从而防止被 C&C 服务器控制。(错误，虚拟桌面本身仍可能因浏览恶意网站而感染僵尸程序)

エ. 内部ネットワークのPCにマルウェアが侵入したとしても，他のPCに感染するのを防ぐ。

→ 即使恶意软件侵入了内部网络的 PC，也能防止其感染其他 PC。(错误，与本次变更 (隔离浏览行为) 无直接关系，属于网络分段/终端隔离的效果)

問10 / 问题 10

■ 原文 (日文)

デジタルフォレンジックスでハッシュ値を利用する目的として、適切なものはどれか。

■ 中文题意

在数字取证 (digital forensics) 中利用哈希值的目的，恰当的是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
デジタルフォレンジックス	digital forensics	数字取证
ハッシュ値	hash value	哈希值
一方向性関数	one-way function	单向函数
復元できないように変換する	convert irreversibly	转换为不可还原
改変されたデータ	altered data	被篡改的数据
証拠	evidence	证据
原本と複製の同一性	identity between original and copy	原件与副本的一致性
証明する	prove	证明
盗聴	eavesdropping	窃听

■ 选项对照

ア. 一方向性関数によってパスワードを復元できないように変換して保存する。

→ 利用单向函数将密码转换为不可还原的形式保存。(错误，这是密码哈希存储的用途，非取证场景中的用途)

イ. 改変されたデータを，証拠となり得るように復元する。

→ 将被篡改的数据恢复为可作为证据的状态。(错误，哈希值本身无法用于恢复数据)

ウ. 証拠となり得るデータについて，原本と複製の同一性を証明する。

→ 对可能成为证据的数据，证明原件与副本之间的同一性。

エ. パスワードの盗聴の有無を検証する。

→ 验证密码是否被窃听。(错误，与哈希值的取证用途无关)

問11 / 问题 11

■ 原文 (日文)

利用者PCの内蔵ストレージが暗号化されていないとき、攻撃者が利用者PCから内蔵ストレージを抜き取り、攻撃者が用意したPCに接続して内蔵ストレージ内の情報を盗む攻撃の対策に該当するものはどれか。

■ 中文题意

当用户 PC 的内置存储未加密时，攻击者从用户 PC 中拆下内置存储器，并将其连接到攻击者准备的 PC 上以窃取存储器中信息的攻击方式，其对策是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
内蔵ストレージ	internal storage	内置存储器
暗号化されていない	not encrypted	未加密
抜き取る	remove / extract	拆卸取出
利用者アカウント	user account	用户账户
ログインパスワード	login password	登录密码
読取り権限	read permission	读取权限
所有者	owner	所有者
HDDパスワード	HDD password	硬盘密码
BIOSパスワード	BIOS password	BIOS 密码

■ 选项对照

ア. 内蔵ストレージにインストールしたOSの利用者アカウントに対して、ログインパスワードを設定する。

→ 为安装在内置存储器上的操作系统的用户账户设置登录密码。（错误，若存储器被拆下后直接连接他机读取原始数据，OS 登录密码不起作用）

イ. 内蔵ストレージに保存したファイルの読取り権限を、ファイルの所有者だけに付与する。

→ 将内置存储器中保存文件的读取权限仅授予文件所有者。（错误，同样在存储器被物理拆卸后失去意义）

ウ. 利用者PC上でHDDパスワードを設定する。

→ 在用户 PC 上设置 HDD 密码。

エ. 利用者PCにBIOSパスワードを設定する。

→ 为用户 PC 设置 BIOS 密码。（错误，BIOS 密码仅限制该 PC 的开机启动，存储器拆下接到别的 PC 后不受此限制）

問12 / 问题 12

■ 原文 (日文)

ルートキットの特徴はどれか。

■ 中文题意

Rootkit (根套件) 的特征是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
ルートキット	rootkit	Rootkit (根套件)
不正に組み込む	maliciously embed	非法植入
ツールの存在を隠す	hide the existence of tools	隐藏工具的存在
カーネル	kernel	内核
脆弱性を分析する	analyze vulnerabilities	分析脆弱性
感染していないことをチェックする	check for absence of infection	检查是否未感染
アクセス可能な通信ポート	accessible communication port	可访问的通信端口
外部から調査する	investigate from outside	从外部进行调查

■ 选项对照

ア. OSなどに不正に組み込んだツールの存在を隠す。

→ 隐藏非法植入操作系统等中的工具的存在。

イ. OSの中核であるカーネル部分の脆弱性を分析する。

→ 分析作为操作系统核心的内核部分的脆弱性。(错误，这是脆弱性分析工具的功能)

ウ. コンピュータがマルウェアに感染していないことをチェックする。

→ 检查计算机是否未感染恶意软件。(错误，这是反恶意软件工具的功能)

エ. コンピュータやルータのアクセス可能な通信ポートを外部から調査する。

→ 从外部调查计算机或路由器上可访问的通信端口。(错误，这是端口扫描器的功能)

問13 / 问题 13

■ 原文 (日文)

BEC (Business E-mail Compromise) に該当するものはどれか。

■ 中文题意

属于 BEC (商业电子邮件诈骗 , Business E-mail Compromise) 的是下列哪一项 ?

■ 重点单词 (日文 → English → 中文)

日文	English	中文
BEC	Business Email Compromise	商业电子邮件诈骗 (BEC)
巧みなだましの手口	sophisticated deceptive tactics	巧妙的欺骗手法
取引先になりすます	impersonate a business partner	冒充交易对象
金銭をだまし取る	swindle money	骗取金钱
送信元を詐称する	spoof the sender	伪造发件人
ブラックリストに登録させる	get blacklisted	使其被列入黑名单
中継に悪用する	abuse for relaying	被滥用用于中继
誹謗中傷メール	defamatory email	诽谤中伤邮件
社会的な信用を損なう	damage social credibility	损害社会信誉

■ 选项对照

ア. 巧みなだましの手口を駆使し、取引先になりすまして偽の電子メールを送り、金銭をだまし取る。

→ 运用巧妙的欺骗手段，冒充交易对象发送虚假邮件，骗取金钱。

イ. 送信元を攻撃対象の組織のメールアドレスに詐称し、多数の実在しないメールアドレスに一度に大量の電子メールを送り、攻撃対象の組織のメールアドレスを故意にブラックリストに登録させて、利用を阻害する。

→ 将发件人伪造为目标组织的邮箱地址，一次性向大量不存在的邮箱地址发送邮件，故意使目标组织的邮箱被列入黑名单从而妨碍其使用。（错误，此为“退信炸弹/黑名单陷害”攻击）

ウ. 第三者からの電子メールが中継できるように設定されたメールサーバを、スパムメールの中継に悪用する。

→ 将设置为可中继第三方邮件的邮件服务器滥用于中继垃圾邮件。（错误，此为“开放式中继 (Open Relay) ”被滥用的情形）

エ. 誹謗中傷メールの送信元を攻撃対象の組織のメールアドレスに詐称し、組織の社会的な信用を大きく損なわせる。

→ 将诽谤中伤邮件的发件人伪造为目标组织的邮箱地址，严重损害该组织的社会信誉。（错误，此为邮件地址伪造用于名誉损害的攻击）

問14 / 问题 14

■ 原文 (日文)

ボットネットにおけるC&Cサーバの役割として、適切なものはどれか。

■ 中文题意

在僵尸网络 (botnet) 中，C&C 服务器的作用是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
ボットネット	botnet	僵尸网络
C&Cサーバ	command and control server	C&C 服务器
コンテンツをキャッシュする	cache content	缓存内容
負荷を軽減する	reduce load	减轻负载
CHAP	Challenge Handshake Authentication Protocol	CHAP 协议
中継する	relay	中继
時刻同期方式	time-synchronous method	时间同步方式
ワンタイムパスワード	one-time password	一次性密码
乗っ取ったコンピュータ	hijacked computer	被劫持的计算机
不正な操作	unauthorized operation	非法操作
命令を出す	issue commands	发出命令

■ 选项对照

ア. Webサイトのコンテンツをキャッシュし、本来のサーバに代わってコンテンツを利用者に配信することによって、ネットワークやサーバの負荷を軽減する。

→ 缓存网站内容，代替原服务器向用户分发内容，以减轻网络和服务器的负载。(错误，这是CDN/缓存服务器的作用)

イ. 外部からインターネットを経由して社内ネットワークにアクセスする際に、CHAPなどのプロトコルを中継することによって、利用者認証時のパスワードの盗聴を防止する。

→ 在从外部经互联网访问公司内网时，通过中继 CHAP 等协议来防止用户认证时密码被窃听。(错误，与 C&C 服务器无关)

ウ. 外部からインターネットを経由して社内ネットワークにアクセスする際に、時刻同期方式を採用したワンタイムパスワードを発行することによって、利用者認証時のパスワードの盗聴を防止する。

→ 在从外部经互联网访问公司内网时，通过发放采用时间同步方式的一次性密码来防止认证密码被窃听。(错误，此为一次性密码令牌系统的作用)

エ. 侵入して乗っ取ったコンピュータに対して、他のコンピュータへの攻撃などの不正な操作をするよう、外部から命令を出したり応答を受け取ったりする。

→ 对已入侵并劫持的计算机，从外部发出指令或接收其应答，使其执行对其他计算机发起攻击等非法操作。

問15 / 问题 15

■ 原文 (日文)

PCへの侵入に成功したマルウェアがインターネット上の指令サーバと通信を行う場合に、宛先ポートとして使用されるTCPポート番号80に関する記述のうち、適切なものはどれか。

■ 中文题意

当成功侵入 PC 的恶意软件与互联网上的指令服务器进行通信时，关于作为目标端口使用的 TCP 端口号 80 的说法，恰当的是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
指令サーバ	command server	指令服务器
宛先ポート	destination port	目标端口
TCPポート番号80	TCP port number 80	TCP 端口号 80
DNSのゾーン転送	DNS zone transfer	DNS 区域传输
ファイアウォールで許可される	be allowed by the firewall	被防火墙允许
HTTPS通信	HTTPS communication	HTTPS 通信
侵入検知システム	intrusion detection system	入侵检测系统
検知される可能性が低い	low probability of being detected	被检测到的可能性低
名前解決	name resolution	域名解析

■ 选项对照

ア. DNSのゾーン転送に使用されることから、通信がファイアウォールで許可されている可能性が高い。

→ 由于该端口用于 DNS 区域传输，因此通信被防火墙放行的可能性较高。(错误，DNS 区域传输通常使用 TCP 53 端口，与 80 端口无关)

イ. WebサイトのHTTPS通信での閲覧に使用されることから、マルウェアと指令サーバとの間の通信が侵入検知システムで検知される可能性が低い。

→ 由于该端口用于网站 HTTPS

通信浏览，因此恶意软件与指令服务器之间的通信被入侵检测系统检测到的可能性较低。(错误，HTTPS 使用的是 443 端口，而非 80 端口)

ウ. Webサイトの閲覧に使用されることから、通信がファイアウォールで許可されている可能性が高い。

→ 由于该端口用于网站浏览 (HTTP)，因此通信被防火墙放行的可能性较高。

エ. ドメイン名の名前解決に使用されることから、マルウェアと指令サーバとの間の通信が侵入検知システムで検知される可能性が低い。

→ 由于该端口用于域名的名称解析，因此恶意软件与指令服务器间的通信被入侵检测系统检测到的可能性较低。(错误，域名解析通常使用 UDP/TCP 53 端口)

問16 / 问题 16

■ 原文 (日文)

特定のサービスやシステムから流出した認証情報を攻撃者が用いて、認証情報を複数のサービスやシステムで使い回している利用者のアカウントへのログインを試みる攻撃はどれか。

■ 中文题意

攻击者利用从特定服务或系统泄露的认证信息，尝试登录那些在多个服务或系统中重复使用相同认证信息的用户账户，这种攻击是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
認証情報	credentials	认证信息
流出する	leak	泄露
使い回す	reuse	重复使用
ログインを試みる	attempt to log in	尝试登录
パスワードリスト攻撃	password list attack	密码列表攻击
ブルートフォース攻撃	brute-force attack	暴力破解攻击
リバースブルートフォース攻撃	reverse brute-force attack	反向暴力破解攻击
レインボーテーブル攻撃	rainbow table attack	彩虹表攻击

■ 选项对照

ア. パスワードリスト攻撃

→ 密码列表攻击。

イ. ブルートフォース攻撃

→ 暴力破解攻击。(错误，指对某一账号穷举尝试所有可能密码)

ウ. リバースブルートフォース攻撃

→ 反向暴力破解攻击。(错误，指固定一个密码对大量账号进行尝试)

エ. レインボーテーブル攻撃

→ 彩虹表攻击。(错误，指利用预先计算好的哈希表来还原密码)

問17 / 问题 17

■ 原文 (日文)

攻撃者が用意したサーバXのIPアドレスが、A社WebサーバのFQDNに対応するIPアドレスとして、B社DNSキャッシュサーバに記憶された。これによって、意図せずサーバXに誘導されてしまう利用者はどれか。ここで、A社、B社の各従業員は自社のDNSキャッシュサーバを利用して名前解決を行う。

■ 中文题意

攻击者准备的服务器 X 的 IP 地址，被作为 A 公司 Web 服务器 FQDN 所对应的 IP 地址，缓存记录在了 B 公司的 DNS 缓存服务器中。因此，会在不知情的情况下被引导至服务器 X 的用户是下列哪一项？此处，A 公司和 B 公司各自的员工均使用本公司的 DNS 缓存服务器进行域名解析。

■ 重点单词 (日文 → English → 中文)

日文	English	中文
FQDN	Fully Qualified Domain Name	完全限定域名 (FQDN)
DNSキャッシュサーバ	DNS cache server	DNS 缓存服务器
記憶される	be recorded / cached	被记录 (缓存)
意図せず誘導される	be unintentionally redirected	在不知情中被引导
名前解決を行う	perform name resolution	进行域名解析
キャッシュポイズニング	cache poisoning	缓存投毒

■ 选项对照

ア. A社WebサーバにアクセスしようとするA社従業員

→ 试图访问 A 公司 Web 服务器的 A 公司员工。(错误，A 公司员工使用的是 A 公司自身的 DNS 缓存服务器，未被投毒)

イ. A社WebサーバにアクセスしようとするB社従業員

→ 试图访问 A 公司 Web 服务器的 B 公司员工。

ウ. B社WebサーバにアクセスしようとするA社従業員

→ 试图访问 B 公司 Web 服务器的 A 公司员工。(错误，被污染的是 B 公司的缓存，且记录对应的是 A 公司网站的域名，与访问 B 公司网站无关)

エ. B社WebサーバにアクセスしようとするB社従業員

→ 试图访问 B 公司 Web 服务器的 B 公司员工。(错误，被污染的缓存记录只影响对 A 公司网站域名的解析)

問18 / 問題 18

■ 原文 (日文)

攻撃者が、多数のオープンリゾルバに対して、“あるドメイン”の存在しないランダムなサブドメインを多数問い合わせる攻撃（ランダムサブドメイン攻撃）を仕掛け、多数のオープンリゾルバが応答した。このときに発生する事象はどれか。

■ 中文题意

攻击者对大量开放式解析器（open resolver）发起攻击，大量查询“某域名”下不存在的随机子域名（随机子域名攻击），大量开放式解析器对此进行了应答。此时会发生的现象是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
オープンリゾルバ	open resolver	开放式解析器
存在しないランダムなサブドメイン	non-existent random subdomain	不存在的随机子域名
ランダムサブドメイン攻撃	random subdomain attack	随机子域名攻击
権威DNSサーバ	authoritative DNS server	权威 DNS 服务器
負荷が掛かる	be under load	受到负载压力
DNS情報が改ざんされる	DNS information is tampered with	DNS 信息被篡改
ゾーン情報	zone information	区域信息
不正に入手される	be illegally obtained	被非法获取

■ 选项对照

ア. “あるドメイン”を管理する権威DNSサーバに対して負荷が掛かる。

→ 对管理“某域名”的权威 DNS 服务器造成负载压力。

イ. “あるドメイン”を管理する権威DNSサーバに登録されているDNS情報が改ざんされる。

→ 管理“某域名”的权威 DNS 服务器上登记的 DNS 信息被篡改。（错误，本攻击不涉及篡改服务器上的记录）

ウ. オープンリゾルバが保持するDNSキャッシュに不正な値を注入される。

→ 向开放式解析器所持有的 DNS 缓存中注入非法数值。（错误，本攻击不涉及缓存投毒）

エ. オープンリゾルバが保持するゾーン情報を不正に入手される。

→ 非法获取开放式解析器所持有的区域信息。（错误，解析器（resolver）通常不持有区域数据，也非本攻击目的）

問19 / 问题 19

■ 原文 (日文)

SEOポイズニングの説明はどれか。

■ 中文题意

关于 SEO 投毒 (SEO poisoning) 的说明是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
SEOポイズニング	SEO poisoning	SEO 投毒
順位付けアルゴリズム	ranking algorithm	排名算法
悪用する	abuse	滥用
検索結果の上位	top of search results	搜索结果前列
意図的に表示させる	intentionally display	故意显示
ワードライビング	wardriving	战争驾驶 (Wardriving)
侵入のパターン	intrusion pattern	入侵模式
検出する	detect	检测
システム権限	system privileges	系统权限

■ 选项对照

ア. Web検索サイトの順位付けアルゴリズムを悪用して，検索結果の上位に，悪意のあるWebサイトを意図的に表示させる。

→ 滥用网络搜索网站的排名算法，故意使恶意网站显示在搜索结果的前列。

イ. 車などで移動しながら，無線LANのアクセスポイントを探し出して，ネットワークに侵入する。

→ 一边乘车等移动，一边搜寻无线局域网接入点，从而侵入网络。（错误，这是“Wardriving (战争驾驶)”的说明）

ウ. ネットワークを流れるパケットから，侵入のパターンに合致するものを検出して，管理者への通知や，検出した内容の記録を行う。

→ 从网络流经的数据包中检测符合入侵模式的内容，并向管理员通知或记录检测内容。（错误，这是IDS (入侵检测系统) 的说明）

エ. マルウェア対策ソフトのセキュリティ上の脆弱性を悪用して，システム権限で不正な処理を実行させる。

→ 利用杀毒软件在安全上的脆弱性，以系统权限执行非法处理。（错误，这是利用软件漏洞进行提权攻击的说明）

問20 / 问题 20

■ 原文 (日文)

データベースで管理されるデータの暗号化に用いることができ、かつ、暗号化と復号とで同じ鍵を使用する暗号方式はどれか。

■ 中文题意

可用于对数据库中管理的数据进行加密，并且加密与解密使用相同密钥的加密方式是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
暗号化と復号	encryption and decryption	加密与解密
同じ鍵を使用する	use the same key	使用相同的密钥
共通鍵暗号方式	symmetric-key cryptography	对称密钥加密方式
AES	Advanced Encryption Standard	AES (高级加密标准)
PKI	Public Key Infrastructure	公钥基础设施 (PKI)
RSA	RSA algorithm	RSA 算法
SHA-256	SHA-256	SHA-256 (哈希算法)

■ 选项对照

ア. AES

→ AES。加密方式，加密和解密使用同一密钥，可用于数据库数据加密)

イ. PKI

→ 公钥基础设施。(错误，PKI 是围绕公开鍵暗号方式建立的证书管理体系，非加密算法本身)

ウ. RSA

→ RSA。(错误，RSA 属于公开鍵暗号方式，加密与解密使用不同的密钥)

エ. SHA-256

→ SHA-256。(错误，SHA-256 是哈希函数，不可逆，不属于加密方式)

問21 / 问题 21

■ 原文 (日文)

OpenPGPやS/MIMEにおいて用いられるハイブリッド暗号方式の特徴はどれか。

■ 中文题意

在 OpenPGP 和 S/MIME 中所使用的混合加密方式 (hybrid cryptosystem) 的特征是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
OpenPGP	OpenPGP	OpenPGP
S/MIME	S/MIME	S/MIME
ハイブリッド暗号方式	hybrid cryptosystem	混合加密方式
公開鍵暗号方式	public-key cryptography	公钥加密方式
共通鍵暗号方式	symmetric-key cryptography	对称密钥加密方式
組み合わせる	combine	组合
鍵管理コスト	key management cost	密钥管理成本
処理性能	processing performance	处理性能
両立を図る	achieve both	力求兼顾

■ 选项对照

ア. 暗号通信方式としてIPsecとTLSを選択可能にすることによって利用者の利便性を高める。

→ 通过使用用户可在 IPsec 与 TLS

两种加密通信方式中进行选择来提高用户便利性。(错误，与混合加密方式的定义无关)

イ. 公開鍵暗号方式と共通鍵暗号方式を組み合わせることによって鍵管理コストと処理性能の両立を図る。

→ 通过将公钥加密方式与对称密钥加密方式组合，力求兼顾密钥管理成本与处理性能。

ウ. 複数の異なる共通鍵暗号方式を組み合わせることによって処理性能を高める。

→ 通过组合多种不同的对称密钥加密方式来提高处理性能。(错误，并非混合加密方式的定义)

エ. 複数の異なる公開鍵暗号方式を組み合わせることによって安全性を高める。

→ 通过组合多种不同的公钥加密方式来提高安全性。(错误，并非混合加密方式的定义)

問22 / 问题 22 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
デジタル署名	digital signature	数字签名
鍵の組み	key pair / combination	密钥组合
適切な	appropriate	恰当的
作成に用いる鍵	key used to create	用于生成的密钥
検証に用いる鍵	key used to verify	用于验证的密钥
共通鍵	common (symmetric) key	共通密钥 (对称密钥)
公開鍵	public key	公钥
秘密鍵	private key	私钥
公開鍵暗号方式	public-key cryptography	公钥加密方式
ハッシュ値	hash value	哈希值
メッセージダイジェスト	message digest	消息摘要
署名の作成	signature creation	签名的生成
署名の検証	signature verification	签名的验证
なりすまし防止	prevent impersonation	防止冒充
改ざん検知	tamper detection	篡改检测
否認防止	non-repudiation	不可否认性
認証局 (CA)	Certificate Authority	认证机构 (CA)
デジタル証明書	digital certificate	数字证书
暗号化	encryption	加密
復号	decryption	解密
対応関係	correspondence	对应关系
組合せ	combination	组合

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問22 デジタル署名に用いる鍵の組みのうち、適切なものはどれか。

	デジタル署名の 作成に用いる鍵	デジタル署名の 検証に用いる鍵
ア	共通鍵	秘密鍵
イ	公開鍵	秘密鍵
ウ	秘密鍵	共通鍵
エ	秘密鍵	公開鍵

問23 メッセージが改ざんされていないかどうかを確認するために、そのメッセージから、ブロック暗号を用いて生成することができるものはどれか。

ア PKI

イ パリティビット

ウ メッセージ認証符号

エ ルート証明書

問24 リスクベース認証に該当するものはどれか。

ア インターネットバンキングでの取引において、取引の都度、乱数表の指定したマス目にある英数字を入力させて認証する。

イ 全てのアクセスに対し、トークンで生成されたワンタイムパスワードを入力させて認証する。

ウ 利用者の IP アドレスなどの環境を分析し、いつもと異なるネットワークからのアクセスに対して追加の認証を行う。

エ 利用者の記憶、持ち物、身体の特徴のうち、必ず二つ以上の方式を組み合わせさせて認証する。

■ 3. 原题对应中文意思

问22 下列关于用于生成数字签名所用密钥组合的说法中，恰当的是哪一项？

数字签名密钥组合表

用于生成数字签名的密钥 用于验证数字签名的密钥

ア 共通鍵（对称密钥） 秘密鍵（私钥）

イ 公開鍵（公钥） 秘密鍵（私钥）

ウ 秘密鍵（私钥） 共通鍵（对称密钥）

エ 秘密鍵（私钥） 公開鍵（公钥）（エ 为正确答案：数字签名采用公钥加密体系，由签名者用自己的私钥对消息摘要进行签名（生成），验证者用与该私钥配对的公钥进行验证）

問23 / 问题 23

■ 原文（日文）

メッセージが改ざんされていないかどうかを確認するために、そのメッセージから、ブロック暗号を用いて生成することができるものはどれか。

■ 中文题意

为了确认消息是否未被篡改，可以利用分组密码从该消息生成的内容是下列哪一项？

■ 重点单词（日文 → English → 中文）

日文	English	中文
メッセージが改ざんされていないか	whether the message has been tampered with	消息是否未被篡改
ブロック暗号	block cipher	分组密码
PKI	Public Key Infrastructure	公钥基础设施（PKI）
パリティビット	parity bit	奇偶校验位
メッセージ認証符号	Message Authentication Code (MAC)	消息认证码（MAC）
ルート証明書	root certificate	根证书

■ 选项对照

ア. PKI

→ 公钥基础设施。（错误，PKI 是证书管理体系，不是从消息生成的校验值）

イ. パリティビット

→ 奇偶校验位。（错误，用于检测传输过程中的随机比特错误，不具备防篡改的密码学强度）

ウ. メッセージ認証符号

→ 消息认证码（MAC）。从消息与共享密钥生成 MAC，用于验证消息完整性）

エ. ルート証明書

→ 根证书。（错误，根证书是证书链信任的起点，与逐条消息的完整性校验无关）

問24 / 问题 24

■ 原文 (日文)

リスクベース認証に該当するものはどれか。

■ 中文题意

属于基于风险的认证 (risk-based authentication) 的是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
リスクベース認証	risk-based authentication	基于风险的认证
乱数表	random number table	随机数表
マス目	grid cell	方格
ワンタイムパスワード	one-time password	一次性密码
環境を分析する	analyze the environment	分析环境
追加の認証	additional authentication	追加认证
記憶，持ち物，身体の特徴	knowledge, possession, biometric characteristics	记忆、持有物、身体特征
二つ以上の方式	two or more methods	两种以上方式

■ 选项对照

ア. インターネットバンキングでの取引において，取引の都度，乱数表の指定したマス目にある英数字を入力させて認証する。

→ 在网上银行交易中，每次交易都要求输入乱数表中指定方格内的字母数字来进行认证。（错误，这是“乱数表认证”方式）

イ. 全てのアクセスに対し，トークンで生成されたワンタイムパスワードを入力させて認証する。

→ 对所有访问都要求输入令牌生成的一次性密码来进行认证。（错误，这是标准的一次性密码认证，未考虑访问环境的风险）

ウ.

利用者のIPアドレスなどの環境を分析し，いつもと異なるネットワークからのアクセスに対して追加の認証を行う。

→ 分析用户的 IP 地址等环境信息，对来自与平时不同网络的访问要求进行追加认证。

エ. 利用者の記憶，持ち物，身体の特徴のうち，必ず二つ以上の方式を組み合わせさせて認証する。

→ 在用户的记忆、持有物、身体特征中，必定组合两种以上方式进行认证。（错误，这是“多因素认证”的定义）

問25 / 问题 25

■ 原文 (日文)

Webサイトで利用されるCAPTCHAに該当するものはどれか。

■ 中文题意

Web 网站中所使用的 CAPTCHA (验证码) 是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
CAPTCHA	CAPTCHA	CAPTCHA (验证码)
応答を求める	request a response	要求作出应答
応答を分析する	analyze the response	分析应答
プレースホルダ	placeholder	占位符
SQL文を組み立てる	construct SQL statements	构造 SQL 语句
一定時間ごとに	at regular intervals	每隔一定时间
乱数を鍵として	using a random number as a key	以随机数作为密钥

■ 选项对照

ア. 人からのアクセスであることを確認できるよう、アクセスした者に応答を求め、その応答を分析する仕組み

→ 为确认访问者是人类而非程序，向访问者要求作出应答并分析该应答的机制。

イ. 不正なSQL文をデータベースに送信しないよう、Webサーバに入力された文字列をプレースホルダに割り当ててSQL文を組み立てる仕組み

→ 为防止向数据库发送非法 SQL 语句，将输入 Web 服务器的字符串分配到占位符中来构造 SQL 语句的机制。（错误，这是预处理语句 (Prepared Statement) 防 SQL 注入的机制)

ウ. 利用者が本人であることを確認できるよう、Webサイトから一定時間ごとに異なるパスワードを要求する仕組み

→ 为确认用户本人身份，网站每隔一定时间要求输入不同密码的机制。（错误，这是时间同步方式一次性密码的机制)

エ. 利用者が本人であることを確認できるよう、乱数をWebサイト側で生成して利用者に送り、利用者側でその乱数を鍵としてパスワードを暗号化し、Webサイトに送り返す仕組み

→ 为确认用户本人身份，由网站生成随机数发送给用户，用户端用该随机数作为密钥加密密码后回传网站的机制。（错误，这是挑战应答 (Challenge-Response) 认证方式)

問26 / 问题 26

■ 原文 (日文)

HTTP over TLS (HTTPS) を用いて実現できるものはどれか。

■ 中文题意

使用 HTTP over TLS (HTTPS) 可以实现的是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
HTTP over TLS (HTTPS)	HTTP over TLS (HTTPS)	HTTP over TLS (HTTPS)
ファイルの改ざん検知	file tampering detection	文件篡改检测
マルウェア検査	malware inspection	恶意软件检查
侵入検知	intrusion detection	入侵检测
デジタル証明書	digital certificate	数字证书
サーバ認証	server authentication	服务器认证

■ 选项对照

ア. Webサーバ上のファイルの改ざん検知

→ Web 服务器上文件的篡改检测。（错误，HTTPS 保护的是通信链路，不检测服务器上文件本身是否被篡改）

イ. Webブラウザが動作するPC上のマルウェア検査

→ 运行 Web 浏览器的 PC 上的恶意软件检查。（错误，与 HTTPS 无关）

ウ. Webブラウザが動作するPCに対する侵入検知

→ 对运行 Web 浏览器的 PC 进行的入侵检测。（错误，与 HTTPS 无关）

エ. デジタル証明書によるサーバ認証

→ 通过数字证书进行的服务器认证。

問27 / 问题 27

■ 原文 (日文)

SPF (Sender Policy Framework) を利用する目的はどれか。

■ 中文题意

使用 SPF (发件人策略框架 , Sender Policy Framework) 的目的是下列哪一项 ?

■ 重点单词 (日文 → English → 中文)

日文	English	中文
SPF	Sender Policy Framework	发件人策略框架 (SPF)
中間者攻撃	man-in-the-middle attack	中间人攻击
不正接続	unauthorized connection	非法连接
なりすまし	spoofing / impersonation	伪装、冒充
検知する	detect	检测
送信ドメイン認証	sender domain authentication	发件人域名认证

■ 选项对照

ア. HTTP通信の経路上での中間者攻撃を検知する。

→ 检测 HTTP 通信路径上的中间人攻击。(错误 , 与 SPF 无关)

イ. LANへのPCの不正接続を検知する。

→ 检测 PC 对局域网的非法连接。(错误 , 与 SPF 无关)

ウ. 内部ネットワークへの侵入を検知する。

→ 检测对内部网络的入侵。(错误 , 与 SPF 无关)

エ. メール送信者のドメインのなりすましを検知する。

→ 检测邮件发件人域名的伪装冒充。

■ 原文 (日文)

電子メールをドメインAの送信者がドメインBの宛先に送信するとき，送信者をドメインAのメールサーバで認証するためのものはどれか。

■ 中文题意

当域名 A 的发件人向域名 B 的收件人发送电子邮件时，用于在域名 A 的邮件服务器上对发件人进行认证的是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
ドメインA/B	domain A / domain B	域名 A / 域名 B
送信者を認証する	authenticate the sender	认证发件人
APOP	Authenticated Post Office Protocol	APOP
POP3S	POP3 over SSL/TLS	POP3S
S/MIME	S/MIME	S/MIME
SMTP-AUTH	SMTP Authentication	SMTP 认证 (SMTP-AUTH)

■ 选项对照

ア. APOP

→ APOP。(错误，是用于邮件接收 (POP3) 阶段的认证协议，非邮件发送阶段)

イ. POP3S

→ POP3S。(错误，是加密版的邮件接收协议)

ウ. S/MIME

→ S/MIME。(错误，用于邮件内容的加密与数字签名，不属于邮件服务器对发件人的登录认证)

エ. SMTP-AUTH

→ SMTP 认证 (SMTP-AUTH) 。

問29 / 问题 29

■ 原文 (日文)

マルウェアの動的解析に該当するものはどれか。

■ 中文题意

属于恶意软件动态分析的是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
マルウェアの動的解析	dynamic malware analysis	恶意软件动态分析
検体	sample	样本
ハッシュ値を計算する	calculate hash value	计算哈希值
既知のマルウェア	known malware	已知恶意软件
照合する	cross-reference	比对
サンドボックス	sandbox	沙箱
動作を観測する	observe behavior	观测行为
逆コンパイルする	decompile	反编译
拡張子が偽装された	disguised file extension	伪装的扩展名

■ 选项对照

ア. 検体のハッシュ値を計算し，オンラインデータベースに登録された既知のマルウェアのハッシュ値のリストと照合してマルウェアを特定する。

→ 计算样本的哈希值，与在线数据库中已登记的已知恶意软件哈希值列表进行比对以确定恶意软件。（错误，这是基于特征码的静态识别方式）

イ. 検体をサンドボックス上で実行し，その動作や外部との通信を観測する。

→ 在沙箱环境中运行样本，观测其行为及与外部的通信。

ウ. 検体をネットワーク上の通信データから抽出し，さらに，逆コンパイルして取得したコードから検体の機能を調べる。

→ 从网络通信数据中提取样本，并对反编译得到的代码进行功能分析。（错误，逆编译分析代码结构属于静态解析）

エ. ハードディスク内のファイルの拡張子とファイルヘッダの内容を基に，拡張子が偽装された不正なプログラムファイルを検出する。

→ 根据硬盘内文件的扩展名与文件头内容，检测出扩展名被伪装的非法程序文件。（错误，属于静态文件特征检查）

問30 / 问题 30

■ 原文 (日文)

Webサーバの検査におけるポートスキャナの利用目的はどれか。

■ 中文题意

在检查 Web 服务器时，使用端口扫描器的目的是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
ポートスキャナ	port scanner	端口扫描器
稼働しているサービス	running services	正在运行的服务
列挙する	enumerate	列举
不要なサービス	unnecessary services	不必要的服务
逸脱	deviation	偏离
アクセスの履歴	access history	访问记录
正規の利用者ID	legitimate user ID	正规用户 ID
コンテンツを直接確認する	directly check content	直接确认内容

■ 选项对照

ア. Webサーバで稼働しているサービスを列挙して，不要なサービスが稼働していないことを確認する。

→ 列举 Web 服务器上正在运行的服务，确认没有不必要的服务在运行。

イ. Webサーバの利用者IDの管理状況を運用者に確認して，情報セキュリティポリシーからの逸脱がないことを調べる。

→ 向运维人员确认 Web 服务器用户 ID

的管理状况，检查是否偏离信息安全策略。（错误，属于人工核查管理制度的审计方法）

ウ. Webサーバへのアクセスの履歴を解析して，不正利用を検出する。

→ 解析对 Web 服务器的访问记录，检测非法利用。（错误，属于日志分析）

エ. 正規の利用者IDでログインし，Webサーバのコンテンツを直接確認して，コンテンツの脆弱性を検出する。

→ 使用正规用户 ID 登录，直接确认 Web

服务器内容，检测内容中的脆弱性。（错误，属于应用层的手工/内部检测方式）

問31 / 问题 31

■ 原文 (日文)

個人情報保護委員会“特定個人情報の適正な取扱いに関するガイドライン（事業者編）令和4年3月一部改正”及びその“Q&A”によれば、事業者によるファイル作成が禁止されている場合はどれか。なお、“Q&A”とは“「特定個人情報の適正な取扱いに関するガイドライン（事業者編）」及び「（別冊）金融業務における特定個人情報の適正な取扱いに関するガイドライン」に関するQ&A 令和4年4月1日更新”のことである。

■ 中文题意

依据个人信息保护委员会《关于特定个人信息妥善处理的指南（事业者篇）令和4年3月部分修订》及其《问答（Q&A）》，事业者被禁止制作相关文件的情形是下列哪一项？此处，“Q&A”是指《关于〈特定个人信息妥善处理的指南（事业者篇）〉及〈（别册）金融业务中特定个人信息妥善处理的指南〉的问答 令和4年4月1日更新》。

■ 重点单词 (日文 → English → 中文)

日文	English	中文
個人情報保護委員会	Personal Information Protection Commission	个人信息保护委员会
特定個人情報	specific personal information (My Number)	特定个人信息（My Number 相关信息）
適正な取扱い	proper handling	妥善处理
ガイドライン	guideline	指南
ファイル作成	file creation	文件制作
禁止されている	be prohibited	被禁止
バックアップファイル	backup file	备份文件
業務成績	job performance	业务绩效
明細表	detailed statement	明细表
支払調書	payment record statement	支付记录表

■ 选项对照

ア. システム障害に備えた特定個人情報ファイルのバックアップファイルを作成する場合

→ 为应对系统故障而制作特定个人信息文件的备份文件的情形。（错误，属于允许的必要业务用途）

イ. 従業員の個人番号を利用して業務成績を管理するファイルを作成する場合

→ 利用员工的个人编号（My Number）来制作管理业务绩效的文件的情形。

ウ. 税務署に提出する資料間の整合性を確認するために個人番号を記載した明細表などチェック用ファイルを作成する場合

→ 为确认提交税务署的资料间的一致性，而制作载有个人编号的明细表等核对用文件的情形。（错误，属于税务相关法定用途范围内的必要文件）

エ. 保険契約者の死亡保険金支払に伴う支払調書ファイルを作成する場合

→ 因支付保险合同人身故保险金而制作支付记录表文件的情形。（错误，属于法律规定的合法用途）

問32 / 问题 32

■ 原文 (日文)

企業が業務で使用しているコンピュータに、記憶媒体を介してマルウェアを侵入させ、そのコンピュータのデータを消去した者を処罰の対象とする法律はどれか。

■ 中文题意

通过存储介质使恶意软件侵入企业业务用计算机，并删除该计算机数据的行为人，会依据下列哪部法律受到处罚？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
記憶媒体	storage media	存储介质
マルウェアを侵入させる	infiltrate malware	使恶意软件侵入
データを消去する	erase data	删除数据
処罰の対象	subject to punishment	处罚对象
刑法	Penal Code	刑法
製造物責任法	Product Liability Act	产品责任法
不正アクセス禁止法	Unauthorized Computer Access Law	禁止非法访问计算机法
プロバイダ責任制限法	Provider Liability Limitation Act	提供者责任限制法

■ 选项对照

ア. 刑法

→ 刑法。”及“电子计算机损坏等业务妨害罪”等条款的处罚对象；由于并非经网络进行未经授权访问，故不适用不正アクセス禁止法)

イ. 製造物責任法

→ 产品责任法。(错误，规范的是因产品缺陷造成损害的民事责任，与本案无关)

ウ. 不正アクセス禁止法

→ 禁止非法访问计算机法。(错误，该法规范的是通过网络利用他人的识别码等实施的未经授权访问行为，本案是通过存储介质物理植入恶意软件，不属于该法调整范围)

エ. プロバイダ責任制限法

→ 提供者责任限制法。(错误，规范的是互联网服务提供者对侵权信息的责任限制及发信者信息披露，与本案无关)

問33 / 问题 33

■ 原文 (日文)

企業が、「特定電子メールの送信の適正化等に関する法律」に定められた特定電子メールに該当する広告宣伝メールを送信する場合に関する記述のうち、適切なものはどれか。

■ 中文题意

企业发送符合《关于规范特定电子邮件发送等的法律》所定义的“特定电子邮件”的广告宣传邮件时，相关叙述中恰当的是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
特定電子メールの送信の適正化等に関する法律	Act on Regulation of Transmission of Specified Electronic Mail	关于规范特定电子邮件发送等的法律
特定電子メール	specified electronic mail	特定电子邮件
広告宣伝メール	advertising email	广告宣传邮件
SMS	Short Message Service	短信 (SMS)
オプトアウト方式	opt-out method	选择退出方式
オプトイン方式	opt-in method	选择加入方式
原則として	in principle	原则上

■ 选项对照

ア. SMSで送信する場合はオプトアウト方式を利用する。

→ 以短信方式发送时，采用选择退出方式。(错误，通过 SMS 发送的特定电子邮件同样适用原则上须采用选择加入方式的规定)

イ. オプトイン方式，オプトアウト方式のいずれかを企業が自ら選択する。

→ 企业可自行在选择加入方式与选择退出方式中任选其一。(错误，法律原则上强制要求采用选择加入方式，企业不能自由选择)

ウ. 原則としてオプトアウト方式を利用する。

→ 原则上采用选择退出方式。(错误，与法律规定相反)

エ. 原則としてオプトイン方式を利用する。

→ 原则上采用选择加入方式。)

問34 / 问题 34

■ 原文 (日文)

A社は、B社と著作物の権利に関する特段の取決めをせず、A社の要求仕様に基づいて、販売管理システムのプログラム作成をB社に委託した。この場合のプログラム著作権の原始的帰属に関する記述のうち、適切なものはどれか。

■ 中文题意

A 公司未与 B 公司就著作物权利作出特别约定，依据 A 公司的需求规格，委托 B 公司制作销售管理系统的程序。此情况下，关于程序著作权原始归属的叙述中，恰当的是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
著作物	copyrighted work	著作物
特段の取決め	special agreement	特别约定
要求仕様	requirement specification	需求规格
プログラム作成を委託する	commission program development	委托制作程序
著作権の原始的帰属	original attribution of copyright	著作权的原始归属
話し合って決定する	decide through discussion	协商决定
共有帰属	joint ownership	共有归属

■ 选项对照

ア. A社とB社が話し合って帰属先を決定する。

→ 由 A 公司与 B 公司协商决定归属方。(错误，著作权法对此已有原则性规定，无需另行协商即可确定)

イ. A社とB社の共有帰属となる。

→ 归 A 公司与 B 公司共有。(错误，在无特别约定的情况下，著作权不当然共有)

ウ. A社に帰属する。

→ 归 A 公司所有。(错误，委托方并非当然取得著作权)

エ. B社に帰属する。

→ 归 B 公司所有。

問35 / 问题 35

■ 原文 (日文)

システムテストの監査におけるチェックポイントのうち、最も適切なものはどれか。

■ 中文题意

在对系统测试进行审计时，最恰当的检查要点是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
システムテスト	system test	系统测试
監査	audit	审计
チェックポイント	checkpoint	检查要点
テストケース	test case	测试用例
網羅的に	comprehensively	全面地
想定されている	be anticipated	被预想到
利用者側の責任者	user-side manager	用户方责任人
業務が行われている環境	production environment	正在开展业务的环境

■ 选项对照

ア. テストケースが網羅的に想定されていること

→ 测试用例是否被全面地设想到。

イ. テスト計画は利用者側の責任者だけで承認されていること

→ 测试计划是否仅由用户方责任人批准。（错误，测试计划的批准通常需要开发方、用户方等相关责任人共同参与，仅由用户方单方面批准并不恰当）

ウ. テストは実際に業務が行われている環境で実施されていること

→ 测试是否在实际正在开展业务的环境中实施。（错误，系统测试原则上应在与本番环境隔离的测试环境中进行，避免影响实际业务）

エ. テストは利用者側の担当者だけで行われていること

→ 测试是否仅由用户方的相关人员进行。（错误，测试通常需要开发方与用户方共同参与）

問36 / 问题 36

■ 原文 (日文)

アクセス制御を監査するシステム監査人の行為のうち、適切なものはどれか。

■ 中文题意

在对访问控制进行审计时，系统审计员的恰当行为是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
アクセス制御	access control	访问控制
システム監査人	system auditor	系统审计员
管理台帳	management ledger	管理台账
作成し，保管する	create and store	制作并保管
管理規程	management regulation	管理规程
閲覧する	review	阅览
管理方針	management policy	管理方针
制定する	establish	制定
運用手続	operation procedure	运用规程
実施する	execute	实施

■ 选项对照

ア. ソフトウェアに関するアクセス制御の管理台帳を作成し，保管した。

→ 制作并保管了软件相关访问控制的管理台账。（错误，制作管理台账属于被审计方的日常管理职责，审计员不应亲自代劳）

イ. データに関するアクセス制御の管理規程を閲覧した。

→ 阅览了数据相关访问控制的管理规程。

ウ. ネットワークに関するアクセス制御の管理方針を制定した。

→ 制定了网络相关访问控制的管理方针。（错误，制定方针属于管理层职责，审计员若参与制定则会丧失独立性）

エ. ハードウェアに関するアクセス制御の運用手続を実施した。

→ 实施了硬件相关访问控制的运用规程。（错误，实际执行运用手续属于运维人员职责，审计员不应参与实际操作）

問37 / 问题 37

■ 原文 (日文)

我が国の証券取引所に上場している企業において、内部統制の整備及び運用に最終的な責任を負っている者は誰か。

■ 中文题意

在我国 (日本) 证券交易所上市的企业中，对内部控制的建立与运行承担最终责任的是谁？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
証券取引所	stock exchange	证券交易所
上場している	listed	上市
内部統制	internal control	内部控制
整備及び運用	establishment and operation	建立与运行
最終的な責任を負う	bear ultimate responsibility	承担最终责任
株主	shareholder	股东
監査役	statutory auditor	监事
業務担当者	business staff	业务负责人
経営者	management / executives	经营者、管理层

■ 选项对照

ア. 株主

→ 股东。(错误，股东是公司的所有者，不直接负责内部控制的建立与运行)

イ. 監査役

→ 监事。(错误，监事的职责是对董事的职务执行情况进行监督，而非负责内部控制本身的建立运行)

ウ. 業務担当者

→ 业务负责人。(错误，业务负责人只是在各自岗位上执行内部控制，而非承担最终责任者)

エ. 経営者

→ 经营者 (管理层)。

問38 / 問題 38

■ 原文 (日文)

ヒューマンエラーに起因する障害を発生しにくくする方法に、エラープルーフ化がある。運用作業におけるエラープルーフ化の例として、最も適切なものはどれか。

■ 中文题意

为降低因人为失误而导致故障发生概率的方法之一是“防错化 (error-proofing)”。在运维作业中，防错化措施的最恰当示例是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
ヒューマンエラー	human error	人为失误
障害	failure	故障
エラープルーフ化	error-proofing	防错化
運用作業	operational work	运维作业
ウィンドウの背景色	window background color	窗口背景颜色
疲労が蓄積する	accumulate fatigue	积累疲劳
交代で休憩を取得する	take turns resting	轮流休息
ヒヤリハット情報	near-miss information	未遂事故信息
教育や訓練	education and training	教育培训

■ 选项对照

ア. 画面上の複数のウィンドウを同時に使用する作業では、ウィンドウを間違えないようにウィンドウの背景色をそれぞれ異なる色にする。

→ 在同时使用屏幕上多个窗口的作业中，为避免误操作窗口，将各窗口的背景色分别设为不同颜色。

イ. 長時間に及ぶシステム監視作業では、疲労が蓄積しないように、2時間おきに交代で休憩を取得する体制にする。

→ 在长时间的系统监视作业中，为避免疲劳积累，建立每隔 2 小时轮流休息的体制。(错误，属于劳务管理层面的疲劳缓解措施，而非结构性防错设计)

ウ.

ミスが発生しやすい作業について、過去に発生したヒヤリハット情報を共有して同じミスを起こさないようにする。

→

对容易发生失误的作业，共享过去发生的未遂事故信息以避免重蹈覆辙。(错误，属于经验教训共享/意识提升类措施)

エ. 臨時の作業を行う際にも落ち着いて作業ができるように、臨時の作業の教育や訓練を定期的に行う。

→ 为使临时作业也能从容进行，定期开展临时作业相关的教育培训。(错误，属于人员能力培养类措施)

■ 原文 (日文)

あるデータセンタでは、受発注管理システムの運用サービスを提供している。次の受発注管理システムの運用中の事象において、インシデントに該当するものはどれか。〔受発注管理システムの運用中の事象〕 夜間バッチ処理において、注文トランザクションデータから注文書出力するプログラムが異常終了した。異常終了を検知した運用担当者から連絡を受けた保守担当者は、緊急出社してサービスを回復し、後日、異常終了の原因となったプログラムの誤りを修正した。

■ 中文题意

某数据中心提供订单管理系统的运维服务。在下述订单管理系统运行过程中发生的事象中，属于事件（incident）的是下列哪一项？〔订单管理系统运行中的事象〕 在夜间批处理中，从订单事务数据输出订单单据的程序发生了异常终止。检测到异常终止的运维负责人联系了维护负责人，维护负责人紧急到岗恢复了服务，并在事后修正了导致异常终止的程序错误。

■ 重点单词 (日文 → English → 中文)

日文	English	中文
受発注管理システム	order management system	订单管理系统
インシデント	incident	事件
夜間バッチ処理	nighttime batch processing	夜间批处理
注文トランザクションデータ	order transaction data	订单事务数据
異常終了	abnormal termination	异常终止
検知する	detect	检测到
緊急出社する	come to the office urgently	紧急到岗
サービスを回復する	restore service	恢复服务
プログラムの誤り	program bug	程序错误
修正する	fix	修正

■ 选项对照

ア. 異常終了の検知

→ 异常终止的检测（这是运维负责人所做的发现行为，本身不是需要恢复处理的服务中断事象）

イ. プログラムの誤り

→ 程序错误（这是造成异常终止的原因，属于问题管理范畴，而非发生时须立即应对的事件本身）

ウ. プログラムの異常終了

→ 程序的异常终止。”，需要紧急恢复处理）

エ. 保守担当者の緊急出社

→ 维护负责人的紧急到岗（这是应对事件所采取的行动，而非事件本身）

問40 / 问题 40

■ 原文 (日文)

ソフトウェア開発プロジェクトにおいてWBSを作成する目的として、適切なものはどれか。

■ 中文题意

在软件开发项目中制作 WBS (工作分解结构) 的目的，恰当的是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
WBS	Work Breakdown Structure	工作分解结构 (WBS)
ソフトウェア開発プロジェクト	software development project	软件开发项目
トレードオフの関係	trade-off relationship	权衡关系
総費用の最適化	total cost optimization	总费用最优化
クリティカルパス	critical path	关键路径
横棒 (バー) で表す	represent with bars	用横条表示
進捗	progress	进度
階層的に詳細化する	hierarchically break down	分层细化
細分化する	subdivide	细分

■ 选项对照

ア. 開発の期間と費用とがトレードオフの関係にある場合に、総費用の最適化を図る。

→ 当开发的工期与费用处于权衡关系时，谋求总费用的最优化。（错误，这是工期-成本优化（如赶工分析）的目的）

イ. 作業の順序関係を明確にして、重点管理すべきクリティカルパスを把握する。

→ 明确作业间的先后顺序关系，把握需要重点管理的关键路径。（错误，这是网络图/PERT 图的作用）

ウ. 作業の日程を横棒 (バー) で表して、作業の開始時点や終了時点，現時点の進捗を明確にする。

→ 用横条表示作业日程，明确作业的开始、结束时点及当前进度。（错误，这是甘特图 (Gantt Chart) 的作用）

エ. 作業を、階層的に詳細化して、管理可能な大きさに細分化する。

→ 将作业进行分层细化，细分为可管理的规模。

問41 / 问题 41

■ 原文 (日文)

プロジェクトの日程計画を作成するのに適した技法はどれか。

■ 中文题意

适合用于制定项目日程计划的技法是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
日程計画	schedule plan	进度计划
PERT	Program Evaluation and Review Technique	计划评审技术 (PERT)
回帰分析	regression analysis	回归分析
時系列分析	time series analysis	时间序列分析
線形計画法	linear programming	线性规划
適した技法	suitable technique	适合的技法

■ 选项对照

ア. PERT

→ 计划评审技术 (PERT)。

イ. 回帰分析

→ 回归分析。(错误, 属于统计学中用于研究变量间关系的分析方法)

ウ. 時系列分析

→ 时间序列分析。(错误, 属于对按时间顺序排列的数据进行趋势分析的方法)

エ. 線形計画法

→ 线性规划。(错误, 属于运筹学中求解约束条件下最优解的数学方法)

問42 / 问题 42

■ 原文 (日文)

一方のコンピュータが正常に機能しているときには、他方のコンピュータが待機状態にあるシステムはどれか。

■ 中文题意

当一台计算机正常运行时，另一台计算机处于待机状态的系统是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
待機状態	standby state	待机状态
デュアルシステム	dual system	双重系统
デュプレックスシステム	duplex system	双工系统
マルチプロセッシングシステム	multiprocessing system	多处理系统
ロードシェアシステム	load-sharing system	负载分担系统
主系統と従系統	primary and secondary systems	主系统与备用系统

■ 选项对照

ア. デュアルシステム

→ 双重系统。(错误，指两台计算机同时运行相同处理并互相校验结果，均处于工作状态，不存在待机方)

イ. デュプレックスシステム

→ 双工系统。运行处理，另一台 (备用系统) 处于待机状态，主系统故障时切换至备用系统)

ウ. マルチプロセッシングシステム

→ 多处理系统。(错误，指多个处理器同时并行处理多项任务，均处于工作状态)

エ. ロードシェアシステム

→ 负载分担系统。(错误，指多台计算机同时分担处理负载，均处于工作状态)

問43 / 问题 43

■ 原文 (日文)

データベースの監査ログを取得する目的として、適切なものはどれか。

■ 中文题意

获取数据库审计日志的目的，恰当的是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
監査ログ	audit log	审计日志
取得する	acquire	获取
権限のない利用者	unauthorized user	无权限用户
アクセスを拒否する	deny access	拒绝访问
チェックポイント	checkpoint	检查点
データ復旧	data recovery	数据恢复
不正な書換えや削除	unauthorized modification or deletion	非法篡改或删除
事前に検知する	detect in advance	事前检测
事後に調査する	investigate afterward	事后调查

■ 选项对照

ア. 権限のない利用者のアクセスを拒否する。

→ 拒绝无权限用户的访问。(错误，这是访问控制机制 (如认证与授权) 的作用，而非日志本身的目的)

イ. チェックポイントからのデータ復旧に使用する。

→ 用于从检查点进行数据恢复。(错误，这是事务日志 (transaction log) 用于故障恢复的目的)

ウ. データの不正な書換えや削除を事前に検知する。

→ 事先检测出数据的非法篡改或删除。(错误，日志记录发生在操作之后，无法用于事前检测)

エ. 問題のあるデータベース操作を事後に調査する。

→ 对有问题的数据库操作进行事后调查。

問44 / 问题 44

■ 原文 (日文)

社内ネットワークのPCから，中継装置を経由してインターネット上のWebサーバにアクセスする。中継装置は宛先のWebサーバのドメイン名からDNSを利用してグローバルIPアドレスを求め，そのグローバルIPアドレス宛てにアクセス要求の転送を行う機能を有する。この中継装置として，適切なものはどれか。

■ 中文题意

从公司内网的 PC 经由中继设备访问互联网上的 Web 服务器。该中继设备具备如下功能：根据目标 Web 服务器的域名，利用 DNS 求出其全球 IP 地址，并将访问请求转发至该全球 IP 地址。该中继设备恰当的是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
中継装置	relay device	中继设备
ドメイン名	domain name	域名
グローバルIPアドレス	global IP address	全球 IP 地址
転送を行う	forward	转发
プロキシサーバ	proxy server	代理服务器
リピータ	repeater	中继器
ルータ	router	路由器
レイヤ2スイッチ	layer 2 switch	二层交换机

■ 选项对照

ア. プロキシサーバ

→ 代理服务器。

イ. リピータ

→ 中继器。(错误，工作在物理层，仅对信号进行放大转发，不涉及域名解析)

ウ. ルータ

→ 路由器。(错误，路由器依据 IP 地址进行路由转发，本身不负责将域名解析为 IP 地址后再代理转发应用层请求)

エ. レイヤ2スイッチ

→ 二层交换机。(错误，工作在数据链路层，依据 MAC 地址转发帧，与域名解析无关)

問45 / 问题 45

■ 原文 (日文)

BPOの説明はどれか。

■ 中文题意

关于 BPO 的说明是下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
BPO	Business Process Outsourcing	业务流程外包 (BPO)
コアビジネス	core business	核心业务
外部の専門的な企業	external specialized company	外部专业企业
委託する	outsource	委托
中断させない	not interrupt	不中断
基準生産計画	master production schedule	主生产计划
部品表	bill of materials	物料清单
所要量	required quantity	所需数量
情報化投資	IT investment	信息化投资
最適化を図る	optimize	谋求优化

■ 选项对照

ア.

災害や事故で被害を受けても，重要事業を中断させない，又は可能な限り中断期間を短くする仕組みを構築すること
→ 即使遭受灾害或事故的损害，也不中断重要业务，或尽可能缩短中断时间的机制构建。（错误，这是 BCP（业务连续性计划）的定义）

イ. 社内業務のうちコアビジネスでない事業に関わる業務の一部又は全部を，外部の専門的な企業に委託すること
→ 将公司内部业务中与非核心业务相关的部分或全部业务，委托给外部专业企业。（定义）

ウ. 製品の基準生産計画，部品表及び在庫情報を基に，資材の所要量と必要な時期を求め，これを基準に資材の手配，納入の管理を支援する生産管理手法のこと
→ 基于产品的主生产计划、物料清单及库存信息，求出物料所需数量与所需时间，并以此为准支援物料筹措与交货管理的生产管理方法。（错误，这是 MRP（物料需求计划）的定义）

エ. プロジェクトを，戦略との適合性や費用対効果，リスクといった観点から評価を行い，情報化投資のバランスを管理し，最適化を図ること
→ 从与战略的契合度、成本效益及风险等角度对项目进行评价，管理信息化投资的平衡并谋求最优化。（错误，这是 IT 投资组合管理（IT Portfolio Management）的定义）

問46 / 问题 46

■ 原文 (日文)

製造業の企業が社会的責任を果たす活動の一環として、雇用創出や生産設備の環境対策に投資することによって、便益を享受するステークホルダは、株主、役員、従業員に加えて、どれか。

■ 中文题意

作为制造业企业履行社会责任活动的一环，通过投资创造就业以及生产设备的环保对策而享受相应利益的利益相关者，除股东、董事、员工之外，还包括下列哪一项？

■ 重点单词 (日文 → English → 中文)

日文	English	中文
社会的責任	social responsibility	社会责任
雇用創出	job creation	创造就业
生産設備の環境対策	environmental measures for production facilities	生产设备的环保措施
投資する	invest	投资
便益を享受する	benefit from	享受利益
ステークホルダ	stakeholder	利益相关者
近隣地域社会の住民	residents of the neighboring community	周边地区居民
原材料の輸入元企業	raw material import source company	原材料进口来源企业
下請企業	subcontractor	分包企业

■ 选项对照

ア. 近隣地域社会の住民

→ 周边地区居民。

イ. 原材料の輸入元企業

→ 原材料进口来源企业。(错误，与雇用创出、生产设备环保投资没有直接的受益关系)

ウ. 製品を購入している消費者

→ 购买产品的消费者。(错误，消费者更多是从产品质量与价格中受益，而非本题所述的雇用与环保投资)

エ. 取引をしている下請企業

→ 有交易往来的分包企业。(错误，与本题所述的雇用创出、环保投资没有直接的受益关系)

問47 / 问题 47 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
期末在庫品	ending inventory	期末库存商品
先入先出法	First-In-First-Out (FIFO)	先入先出法
評価する	value	计价
在庫評価額	inventory valuation amount	库存评价额
何千円か	how many thousand yen	多少千日元
摘要	description	摘要
数量	quantity	数量
単価	unit price	单价
期首在庫	beginning inventory	期初库存
仕入	purchase	采购、进货
期末在庫	ending inventory	期末库存
棚卸資産	inventory asset	存货资产
移動平均法	moving average method	移动平均法
総平均法	weighted average method	加权平均法
後入先出法	Last-In-First-Out (LIFO)	后入先出法
単位：千円	unit: thousand yen	单位：千日元
個	unit (piece)	个 (单位)
原価	cost	成本
払出単価	issue unit cost	出库单价
残高	balance	余额

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問47 表から，期末在庫品を先入先出法で評価した場合の期末の在庫評価額は何千円か。

摘要		数量（個）	単価（千円）
期首在庫		10	10
仕入	4月	1	11
	6月	2	12
	7月	3	13
	9月	4	14
期末在庫		12	

ア 132

イ 138

ウ 150

エ 168

問48 製造原価明細書から損益計算書を作成したとき，売上総利益は何千円か。

単位 千円		単位 千円	
製造原価明細書		損益計算書	
材料費	400	売上高	1,000
労務費	300	売上原価	
経費	200	期首製品棚卸高	120
当期総製造費用		当期製品製造原価	
期首仕掛品棚卸高	150	期末製品棚卸高	70
期末仕掛品棚卸高	250	売上原価	
当期製品製造原価		売上総利益	

ア 150

イ 200

ウ 310

エ 450

■ 3. 原题对应中文意思

问47 根据下表，若采用先入先出法 (FIFO) 对期末库存商品进行计价，期末库存的评价额为多少千日元？

库存明细表 (单位：千日元)

摘要 数量 (个) 单价 (千日元)

期首在库 10 10

采购 4 月 1 11

6 月 2 12

7 月 3 13

9 月 4 14

期末在库 12 —

解答群

ア 132

イ 138

ウ 150 (正确答案：期初库存与各月采购的总数量为 $10+1+2+3+4=20$ 个，期末库存为 12

个。按先入先出法，期末库存由最后入库的批次构成，即：期初库存剩余 2 个 $\times$ 10 千日元 + 4月 1 个 $\times$ 11 千日元 + 6月 2 个 $\times$ 12 千日元 + 7月 3 个 $\times$ 13 千日元 + 9月 4 个 $\times$ 14 千日元 = $20 + 11 + 24 + 39 + 56 = 150$ 千日元)

エ 168

問48 / 问题 48 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
製造原価明細書	statement of cost of manufacturing	制造成本明细表
損益計算書	income statement	损益表
売上総利益	gross profit	销售毛利
材料費	material cost	材料费
労務費	labor cost	劳务费 (人工费)
経費	manufacturing overhead	制造费用 (经费)
当期総製造費用	total manufacturing cost for the period	本期总制造费用
期首仕掛品棚卸高	beginning work-in-process inventory	期初在制品盘存
期末仕掛品棚卸高	ending work-in-process inventory	期末在制品盘存
当期製品製造原価	cost of goods manufactured	本期产品制造成本
売上高	sales revenue	销售额
売上原価	cost of goods sold	销售成本
期首製品棚卸高	beginning finished goods inventory	期初产品盘存
期末製品棚卸高	ending finished goods inventory	期末产品盘存
単位 千円	unit: thousand yen	单位：千日元
仕掛品	work in process	在制品
製品	finished goods	产成品
原価計算	cost accounting	成本核算
棚卸高	inventory amount	盘存额
何千円か	how many thousand yen	多少千日元

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問47 表から，期末在庫品を先入先出法で評価した場合の期末の在庫評価額は何千円か。

摘要		数量（個）	単価（千円）
期首在庫		10	10
仕入	4月	1	11
	6月	2	12
	7月	3	13
	9月	4	14
期末在庫		12	

ア 132

イ 138

ウ 150

エ 168

問48 製造原価明細書から損益計算書を作成したとき，売上総利益は何千円か。

単位 千円		単位 千円	
製造原価明細書		損益計算書	
材料費	400	売上高	1,000
労務費	300	売上原価	
経費	200	期首製品棚卸高	120
当期総製造費用		当期製品製造原価	
期首仕掛品棚卸高	150	期末製品棚卸高	70
期末仕掛品棚卸高	250	売上原価	
当期製品製造原価		売上総利益	

ア 150

イ 200

ウ 310

エ 450

■ 3. 原题对应中文意思

问48 根据下方的制造成本明细表编制损益表时，销售毛利为多少千日元？

制造成本明细表（单位：千日元）

材料费 400

劳务费（人工费）300

制造费用（经费）200

本期总制造费用（需计算， $= 400 + 300 + 200 = 900$ ）

期初在制品盘存 150

期末在制品盘存 250

本期产品制造成本（需计算， $= 900 + 150 - 250 = 800$ ）

损益表（单位：千日元）

销售额 1,000

销售成本：

期初产品盘存 120

本期产品制造成本（同上，800）

期末产品盘存 70

销售成本合计（需计算， $= 120 + 800 - 70 = 850$ ）

销售毛利（需计算， $= 1,000 - 850 = 150$ ）

解答群

ア 150（正确答案：本期总制造费用 $= 400 + 300 + 200 = 900$ ；本期产品制造成本 $= 900 + 150 - 250 = 800$ ；销售成本 $= 120 + 800 - 70 = 850$ ；销售毛利 $= 1,000 - 850 = 150$ ）

イ 200

ウ 310

エ 450

問49 / 问题 49 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
広告制作ビジネス	advertising production business	广告制作业务
人事業務	HR operations	人事业务
委託を検討する	consider outsourcing	考虑委托外包
採用予定者	prospective new hire	录用预定人员
誓約書	written pledge	誓约书
源泉徴収票	withholding tax statement	源泉征收票 (扣缴凭证)
PDFファイルに変換する	convert to PDF file	转换为 PDF 文件
ファイルサーバに格納する	store on a file server	保存到文件服务器
専任の従業員を割り当てる	assign a dedicated employee	安排专职员工
複合機	multifunction printer (MFP)	复合机 (多功能一体机)
スキャン機能	scan function	扫描功能
利用者ID	user ID	用户 ID
パネルに入力する	input on the panel	在操作面板上输入
鍵で暗号化する	encrypt with a key	用密钥加密
電子メールに添付する	attach to an email	作为附件添加到邮件中
保存先のURL	storage location URL	保存地址的 URL
秘密保持契約	non-disclosure agreement (NDA)	保密协议
業務委託契約	business outsourcing contract	业务委托合同
情報セキュリティリスクの評価	information security risk assessment	信息安全风险评估
差出人アドレス	sender address	发件人地址
件名	subject line	邮件主题
添付ファイル名	attachment file name	附件文件名
初期設定	default setting	初始设置
ベンダーのWebサイト	vendor's website	厂商网站
公開されている	be published / publicly available	被公开
情報システム部	IT department	信息系统部
対策が必要である	measures are required	需要采取对策
なりすまして	by impersonating	冒充
不正に持ち出す	illegally remove / exfiltrate	非法带出
個人情報が漏えいする	personal information is leaked	个人信息泄露
マルウェア感染する	become infected with malware	感染恶意软件
盗聴する	eavesdrop	窃听
身代金を要求する	demand ransom	索要赎金
復号鍵	decryption key	解密密钥

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問49 A社は、放送会社や運輸会社向けに広告制作ビジネスを展開している。A社は、人事業務の効率化を図るべく、人事業務の委託を検討することにした。A社が委託する業務（以下、B業務という）を図1に示す。

- ・採用予定者から郵送されてくる入社時の誓約書、前職の源泉徴収票などの書類をPDFファイルに変換し、ファイルサーバに格納する。
(省略)

図1 B業務

委託先候補のC社は、B業務について、次のようにA社に提案した。

- ・B業務だけに従事する専任の従業員を割り当てる。
- ・B業務では、図2の複合機のスキャン機能を使用する。

- ・スキャン機能を使用する際は、従業員ごとに付与した利用者IDとパスワードをパネルに入力する。
- ・スキャンしたデータをPDFファイルに変換する。
- ・PDFファイルを従業員ごとに異なる鍵で暗号化して、電子メールに添付する。
- ・スキャンを実行した本人宛てに電子メールを送信する。
- ・PDFファイルが大きい場合は、PDFファイルを添付する代わりに、自社の社内ネットワーク上に設置したサーバ（以下、Bサーバという）に自動的に保存し、保存先のURLを電子メールの本文に記載して送信する。

図2 複合機のスキャン機能（抜粋）

A社は、C社と業務委託契約を締結する前に、秘密保持契約を締結して、C社を訪問し、業務委託での情報セキュリティリスクの評価を実施した。その結果、図3の発見があった。

- ・複合機のスキャン機能では、電子メールの差出人アドレス、件名、本文及び添付ファイル名を初期設定¹⁾の状態で使用しており、誰がスキャンを実行しても同じである。
- ・複合機のスキャン機能の初期設定情報はベンダーのWebサイトで公開されており、誰でも閲覧できる。

注¹⁾ C社の情報システム部だけが複合機の初期設定を変更可能である。

図3 発見事項

そこで、A 社では、初期設定の状態のままでは A 社にとって情報セキュリティリスクがあり、対策が必要であると評価した。

設問 対策が必要であると A 社が評価した情報セキュリティリスクはどれか。解答群のうち、最も適切なものを選べ。

解答群

- ア B 業務に従事する従業員が、B 業務に従事する他の従業員になりすまして複合機のスキャン機能を使用し、PDF ファイルを取得して不正に持ち出す。その結果、A 社の採用予定者の個人情報が漏えいする。
- イ B 業務に従事する従業員が、攻撃者からの電子メールを複合機からのものとして本文中にある URL をクリックし、攻撃者が用意した Web サイトにアクセスしてマルウェア感染する。その結果、A 社の採用予定者の個人情報が漏えいする。
- ウ 攻撃者が、複合機から送信される電子メールを盗聴し、添付ファイルを暗号化して身代金を要求する。その結果、A 社が復号鍵を受け取るために多額の身代金を支払うことになる。
- エ 攻撃者が、複合機から送信される電子メールを盗聴し、本文に記載されている URL を SNS に公開する。その結果、A 社の採用予定者の個人情報が漏えいする。

■ 3. 原题对应中文意思

问49 A 公司面向广播公司和运输公司开展广告制作业务。A

公司为提高人事业务效率，正在研究将部分人事业务外包。图1 展示了 A 公司拟委托的业务（以下称“B 业务”）。

图1 B 业务（节选）

· 将录用预定人员通过邮寄方式寄来的入职誓约书、前职单位开具的源泉征收票等文件转换为 PDF 文件，并保存到文件服务器中。

（以下省略）

委托候选方 C 公司就 B 业务向 A 公司提出了如下方案：

- 安排专职员工，专门负责 B 业务。
- B 业务中将使用图2 所示复合机（多功能一体机）的扫描功能。

图2 复合机的扫描功能（节选）

- 使用扫描功能时，需在操作面板上输入按员工分别授予的用户 ID 和密码。
- 将扫描得到的数据转换为 PDF 文件。
- 用按员工各不相同的密钥对 PDF 文件加密后，作为附件添加到电子邮件中。
- 邮件发送给执行本次扫描操作的本人。
- 若 PDF 文件较大，则不作为附件发送，而是自动保存到自有公司内网中设置的服务器（以下称“B 服务器”），并将保存地址的 URL 记载在邮件正文中发送。

在与 C 公司签订业务委托合同之前，A 公司先与其签订了保密协议，并对 C 公司进行了实地走访，评估了业务委托中的信息安全风险，结果发现了图3 所示情况。

图3 发现事项

- 复合机扫描功能所发送电子邮件的发件人地址、主题、正文及附件文件名，均使用初始设置^{注1)}状态，无论谁执行扫描操作，结果都相同。
- 复合机扫描功能的初始设置信息在厂商网站上公开，任何人均可查阅。

注1) 只有 C 公司的信息系统部门才能变更复合机的初始设置。

因此，A 公司评估认为：若保持初始设置状态不变，对 A 公司而言存在信息安全风险，需要采取相应对策。

设问 A 公司评估认为需要采取对策的信息安全风险是下列哪一项？请从解答群中选出最恰当的一项。

解答群

ア 负责 B 业务的员工冒充其他负责 B 业务的员工使用复合机的扫描功能，获取 PDF 文件后非法带出。结果导致 A 公司录用预定人员的个人信息泄露。

イ 负责 B 业务的员工误将攻击者发送的邮件当作复合机所发的邮件，点击了正文中的 URL，访问了攻击者准备的网站，从而感染恶意软件。结果导致 A 公司录用预定人员的个人信息泄露。（正确答案：由于发件人地址、主题、正文、附件名等邮件特征均为固定的初始设置内容，且该初始设置信息在厂商网站上公开可查，攻击者可轻易伪造出与复合机发送的邮件几乎完全一致的钓鱼邮件，诱使员工点击恶意 URL 而感染恶意软件，进而导致个人信息泄露）

ウ 攻击者窃听复合机发送的电子邮件，将附件加密后索要赎金。结果导致 A 公司为取得解密密钥而不得不支付巨额赎金。

エ 攻击者窃听复合机发送的电子邮件，将正文中记载的 URL 公开发布到社交网络（SNS）上。结果导致 A 公司录用预定人员的个人信息泄露。

問50 / 问题 50 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
分析・計測機器	analytical and measuring instruments	分析、计测仪器
分析受託業務	contract analysis services	分析受托业务
分析機器メーカー	analytical instrument manufacturer	分析仪器制造商
情報セキュリティリスクアセスメント手順	information security risk assessment procedure	信息安全风险评估流程
機密性	confidentiality	机密性
完全性	integrity	完整性
可用性	availability	可用性
評価値	evaluation value / score	评价值
情報資産の重要度	importance of information asset	信息资产的重要度
脅威	threat	威胁
脆弱性	vulnerability	脆弱性
リスク値	risk value	风险值
情報資産管理台帳	information asset management ledger	信息资产管理台账
しきい値	threshold value	阈值
受容可能なリスク	acceptable risk	可接受风险
保有	risk retention	风险保有 (接受)
リスク対応	risk treatment	风险应对
安全管理措置	safety control measures	安全管理措施
守秘義務	confidentiality obligation	保密义务
営業秘密	trade secret	商业秘密
ノウハウ	know-how	技术诀窍 (Know-how)
特許出願前	before patent application	专利申请前
関係者外秘	confidential to non-related parties	关系者外保密信息
社外秘情報	internal confidential information	社外秘信息
公開情報	public information	公开信息
改ざんされる	be tampered with	被篡改
深刻な影響	serious impact	严重影响
事業に影響がある	affect business operations	影响业务运营
廃版製品カタログ	discontinued product catalog	停产产品目录
画像付きで一覧表示する	display in a list with images	带图片列表展示
操作マニュアル	operation manual	操作手册
ダウンロードして利用する	download and use	下载使用

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問50 A社は、分析・計測機器などの販売及び機器を利用した試料の分析受託業務を行う分析機器メーカーである。A社では、図1の“情報セキュリティリスクアセスメント手順”に従い、年一度、情報セキュリティリスクアセスメントの結果をまとめている。

・ 情報資産の機密性、完全性、可用性の評価値は、それぞれ 0～2 の 3 段階とし、表 1 のとおりとする。
・ 情報資産の機密性、完全性、可用性の評価値の最大値を、その情報資産の重要度とする。
・ 脅威及び脆弱性の評価値は、それぞれ 0～2 の 3 段階とする。
・ 情報資産ごとに、様々な脅威に対するリスク値を算出し、その最大値を当該情報資産のリスク値として情報資産管理台帳に記載する。ここで、情報資産の脅威ごとのリスク値は、次の式によって算出する。 $\text{リスク値} = \text{情報資産の重要度} \times \text{脅威の評価値} \times \text{脆弱性の評価値}$
・ 情報資産のリスク値のしきい値を 5 とする。
・ 情報資産ごとのリスク値がしきい値以下であれば受容可能なリスクとする。
・ 情報資産ごとのリスク値がしきい値を超えた場合は、保有以外のリスク対応を行うことを基本とする。

図1 情報セキュリティリスクアセスメント手順

表1 情報資産の機密性、完全性、可用性の評価基準

評価値	評価基準	該当する情報の例
機密性	2 法律で安全管理措置が義務付けられている。	・ 健康診断の結果、保健指導の記録 ・ 給与所得の源泉徴収票
	2 取引先から守秘義務の対象として指定されている。	・ 取引先から秘密と指定されて受領した資料 ・ 取引先の公開前の新製品情報
	2 自社の営業秘密であり、漏えいすると自社に深刻な影響がある。	・ 自社の独自技術、ノウハウ ・ 取引先リスト ・ 特許出願前の発明情報
	1 関係者外秘情報又は社外秘情報である。	・ 見積書、仕入価格など取引先や顧客との商取引に関する情報 ・ 社内規程、事務処理要領
	0 公開情報である。	・ 自社製品カタログ、自社 Web サイト掲載情報
完全性	2 法律で安全管理措置が義務付けられている。	・ 健康診断の結果、保健指導の記録 ・ 給与所得の源泉徴収票
	2 改ざんされると自社に深刻な影響、又は取引先や顧客に大きな影響がある。	・ 社内規程、事務処理要領 ・ 自社の独自技術、ノウハウ ・ 設計データ（原本）
	1 改ざんされると事業に影響がある。	・ 受発注情報、決済情報、契約情報 ・ 設計データ（印刷物）
	0 改ざんされても事業に影響はない。	・ 廃版製品カタログデータ
可用性	(省略)	

A 社は、自社の Web サイトをインターネット上に公開している。A 社の Web サイトは、自社が取り扱う分析機器の情報を画像付きで一覧表示する機能を有しており、主に A 社で販売する分析機器に関する機能の説明や操作マニュアルを掲載している。A 社で分析機器を購入した顧客は、A 社の Web サイトからマニュアルをダウンロードして利用することが多い。A 社の Web サイトは、製品を販売する機能を有していない。

A 社は、年次の情報セキュリティリスクアセスメントの結果を、表 2 にまとめた。

表 2 A 社の情報セキュリティリスクアセスメント結果（抜粋）

情報資産名称	説明	機密性の評価値	完全性の評価値	可用性の評価値	情報資産の重要度	脅威の評価値	脆弱性の評価値	リスク値
社内規程	行動規範や判断基準を含めた社内ルール	1	2	1	2	1	1	2
設計データ（印刷物）	A 社における主力製品の設計図	（省略）						
自社 Web サイトにあるコンテンツ	分析機器の情報	a1	a2	2	a3	2	2	a4

設問 表 2 中の a1 ～ a4 に入れる数値の適切な組合せを、a に関する解答群から選べ。

a に関する解答群

	a1	a2	a3	a4
ア	0	0	2	8
イ	0	1	2	8
ウ	0	2	1	4
エ	0	2	2	8
オ	1	0	2	4
カ	1	1	2	8
キ	1	2	1	4
ク	1	2	2	8

■ 3. 原题对应中文意思

问50 A 公司是从事分析、计测仪器等设备销售，以及利用设备提供试样分析受托业务的分析仪器制造商。A 公司依据图1所示的“信息安全风险评估流程”，每年一次汇总信息安全风险评估的结果。

图1 信息安全风险评估流程

- 信息资产的机密性、完整性、可用性的评价价值，分别取 0~2 三档，按表1 执行。
- 取信息资产机密性、完整性、可用性评价价值中的最大值，作为该信息资产的重要度。
- 威胁及脆弱性的评价价值，分别取 0~2 三档。
- 针对每项信息资产，计算其面对各种威胁的风险值，取其最大值作为该信息资产的风险值，记录于信息资产管理台账中。此处，信息资产针对某威胁的风险值，按以下公式计算：
风险值 = 信息资产的重要度 × 威胁的评价价值 × 脆弱性的评价价值
- 信息资产风险值的阈值定为 5。
- 若信息资产的风险值小于等于阈值，则视为可接受风险。
- 若信息资产的风险值超过阈值，原则上应采取“保有”以外的风险应对措施。

表1 信息资产机密性、完整性、可用性评价基准

- 【机密性】
- 评价价值 2：法律规定必须采取安全管理措施的信息 —— 例：体检结果、保健指导记录；工资薪金的源泉征收票
- 评价价值 2：被交易方指定为保密义务对象的信息 ——
- 例：从交易方处获得并被指定为保密的资料；交易方公开前的新产品信息
- 评价价值 2：属于本公司商业秘密，一旦泄露将对本公司造成严重影响的信息 ——
- 例：本公司独有技术、Know-how；交易方名单；专利申请前的发明信息
- 评价价值 1：属于关系者外保密信息或社外秘信息 ——
- 例：报价单、进货价格等与交易方或客户商务往来相关的信息；公司内部规程、事务处理要领
- 评价价值 0：公开信息 —— 例：本公司产品目录、本公司网站公开信息
- 【完整性】
- 评价价值 2：法律规定必须采取安全管理措施的信息 —— 例：体检结果、保健指导记录；工资薪金的源泉征收票
- 评价价值 2：被篡改会对本公司造成严重影响，或对交易方、客户造成重大影响的信息 ——
- 例：公司内部规程、事务处理要领；本公司独有技术、Know-how；设计数据（原件）
- 评价价值 1：被篡改会影响业务运营的信息 —— 例：订购信息、结算信息、合同信息；设计数据（印刷件）
- 评价价值 0：即使被篡改也不影响业务运营的信息 —— 例：已停产产品的目录数据
- 【可用性】（省略）

A 公司将本公司网站公开在互联网上。该网站具有将本公司经营的分析仪器信息附带图片进行列表展示的功能，主要刊载 A 公司所销售分析仪器的功能说明及操作手册。购买了 A 公司分析仪器的客户，多从 A 公司网站下载操作手册使用。A 公司网站不具备销售产品的功能。

A 公司将年度信息安全风险评估的结果汇总为表2。

表2 A 公司信息安全风险评估结果（节选）

- 信息资产名称：公司内部规程 说明：包含行动规范和判断标准的公司内部规则 机密性评价价值 1 完整性评价价值 2 可用性评价价值 1 信息资产重要度 2 威胁评价价值 1 脆弱性评价价值 1 风险值 2
- 信息资产名称：设计数据（印刷件） 说明：A 公司主力产品的设计图（其余数值省略）
- 信息资产名称：本公司网站上的内容 说明：分析仪器的相关信息 机密性评价价值 a1 完整性评价价值 a2 可用性评价价值 2 信息资产重要度 a3 威胁评价价值 2 脆弱性评价价值 2 风险值 a4

设问 表2 中 a1~a4 处应填入的数值组合，恰当的是哪一项？请从关于 a 的解答群中选出。

关于 a 的解答群

a1 a2 a3 a4

ア 0 0 2 8

イ 0 1 2 8

ウ 0 2 1 4

エ 0 2 2 8（正确答案：网站上展示的产品信息属于面向公众公开的内容，因此机密性评价价值 a1 = 0；该内容若被篡改（如错误的产品说明或操作手册）会对本公司及使用该网站的客户造成较大影响，因此完整性评价价值 a2 = 2；重要度取机密性、完整性、可用性三者中的最大值，即

$a_3 = \max(0, 2, 2) = 2$; 风险值 = 重要度 $\times$ 威胁评价价值 $\times$ 脆弱性评价价值 = $2 \times 2 \times 2 = 8 = a_4$)

才 1 0 2 4

力 1 1 2 8

キ 1 2 1 4

ク 1 2 2 8

問51 / 问题 51 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
金属加工	metal processing	金属加工
従業員50名の企業	company with 50 employees	50 名员工的企业
サイバー攻撃	cyberattack	网络攻击
情報セキュリティリーダー	information security leader	信息安全负责人
SECURITY ACTION	SECURITY ACTION program	SECURITY ACTION (安全行动宣言) 制度
自己宣言する制度	self-declaration system	自我宣言制度
一つ星を宣言する	declare one-star status	宣言一星级
情報セキュリティ5か条	Five Information Security Rules	信息安全五条准则
取組状況を評価する	evaluate the state of implementation	评价落实情况
標準ソフト	standard software	标准软件
非標準ソフト	non-standard software	非标准软件
自動更新機能	automatic update function	自动更新功能
最新の状態に更新する	update to the latest state	更新至最新状态
一部のPCについて実施している	implemented on some PCs	仅在部分 PC 上实施
実施している	implemented	已实施
EDR (Endpoint Detection and Response)	Endpoint Detection and Response	端点检测与响应 (EDR)
プロセスの起動・終了を記録する	record process start/end	记录进程的启动与终止
設定ルール	configuration rule	设定规则
IT資産管理ツール	IT asset management tool	IT 资产管理工具
脆弱性修正プログラム	vulnerability patch	漏洞修补程序
自動適用	automatic application	自动应用
インストール禁止	installation prohibition	禁止安装
強制アンインストール	forced uninstallation	强制卸载
SIEM (Security Information and Event Management)	Security Information and Event Management	安全信息与事件管理 (SIEM)
ログデータ	log data	日志数据
一括管理	centralized management	统一管理
セキュリティ上の脅威を発見する	discover security threats	发现安全威胁

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問51 A 社は、金属加工を行っている従業員 50 名の企業である。同業他社がサイバー攻撃を受けたというニュースが増え、A 社の社長は情報セキュリティに対する取組が必要であると考え、新たに情報セキュリティリーダーをおくことにした。

社長は、どのような取組が良いかを検討するよう、情報セキュリティリーダーに任命された B 主任に指示した。B 主任は、調査の結果、IPA が実施している SECURITY ACTION への取組を社長に提案した。

SECURITY ACTION とは、中小企業自らが、情報セキュリティ対策に取り組むことを自己宣言する制度であるとの説明を受けた社長は、SECURITY ACTION の一つ星を宣言するために情報セキュリティ 5 か条に取り組むことを決め、B 主任に、情報セキュリティ 5 か条への自社での取組状況を評価するように指示した。

B 主任の評価結果は表 1 のとおりであった。

表 1 B 主任の評価結果

情報セキュリティ 5 か条		評価結果
1	OS やソフトウェアは常に最新の状態にしよう！	一部の PC について実施している
2	(省略)	(省略)
3	パスワードを強化しよう！	(省略)
4	共有設定を見直そう！	(省略)
5	脅威や攻撃の手口を知ろう！	(省略)

表 1 中の 1 の評価結果について B 主任は、次のとおり説明した。

- ・ A 社が従業員に PC を貸与する時に導入した OS と A 社の業務で利用しているソフトウェア（以下、標準ソフトという）は、自動更新機能を使用して最新の状態に更新している。
- ・ それ以外のソフトウェア（以下、非標準ソフトという）はどの程度利用されているか分からないので、試しに数台の PC を確認したところ、大半の PC で利用されていた。最新の状態に更新されていない PC も存在した。

A 社では表 1 中の 1 について評価結果を“実施している”にするために新たに追加すべき対策として 2 案を考え、どちらかを採用することにした。

設問 表 1 中の 1 の評価結果を“実施している”にするために A 社で新たに追加すべき対策として考えられるものは次のうちどれか。考えられる対策だけを全て挙げた組合せを，解答群の中から選べ。

- (一) PC 上のプロセスの起動・終了を記録する Endpoint Detection and Response (EDR) の導入
- (二) PC の OS 及び標準ソフトを最新の状態に更新するという設定ルールの導入
- (三) 全ての PC への脆弱性^{ぜい}修正プログラムの自動適用を行う IT 資産管理ツールの導入
- (四) 非標準ソフトのインストール禁止及び強制アンインストール
- (五) ログデータを一括管理，分析して，セキュリティ上の脅威を発見するための Security Information and Event Management (SIEM) の導入

解答群

- | | | |
|------------|------------|------------|
| ア (一), (二) | イ (一), (三) | ウ (一), (四) |
| エ (一), (五) | オ (二), (三) | カ (二), (四) |
| キ (二), (五) | ク (三), (四) | ケ (三), (五) |
| コ (四), (五) | | |

■ 3. 原题对应中文意思

问51 A 公司是一家从事金属加工、拥有 50 名员工的企业。由于同行企业遭受网络攻击的新闻增多，A 公司社长认为有必要采取信息安全相关措施，因此新设了信息安全负责人一职。

社长指示被任命为信息安全负责人的 B 主任研究应采取何种举措。B 主任经调研后，向社长提议参与 IPA 推行的 SECURITY ACTION 活动。

社长在得知 SECURITY ACTION 是由中小企业自主宣告将开展信息安全对策的一项自我宣言制度后，决定为宣告 SECURITY ACTION 的“一星级”而落实“信息安全五条准则”，并指示 B 主任评价本公司在信息安全五条准则上的落实情况。

B 主任的评价结果如表1 所示。

表1 B 主任的评价结果

信息安全五条准则 评价结果

1 操作系统和软件要始终保持最新状态！ 仅在部分 PC 上实施

2 (省略) (省略)

3 强化密码！ (省略)

4 重新审视共享设置！ (省略)

5 了解威胁及攻击手法！ (省略)

针对表1 中第 1 条的评价结果，B 主任作出如下说明：

- A 公司在向员工出借 PC 时安装的操作系统，以及 A 公司业务中使用的软件（以下称“标准软件”），均使用自动更新功能保持在最新状态。
- 除此之外的其他软件（以下称“非标准软件”），因不清楚其使用程度，尝试抽查了数台 PC，发现大部分 PC 都在使用这些软件，其中也存在未更新到最新状态的 PC。

为使表1 中第 1 条的评价结果变为“已实施”，A 公司考虑了两个新增对策方案，将采用其中之一。

设问 为使表1 中第 1 条的评价结果变为“已实施”，A 公司应新增采取的对策，考虑到的方案如下所示。请从解答群中选出全部包含所有恰当对策的组合。

- (一) 引入可记录 PC 上进程启动、终止情况的端点检测与响应 (EDR) 系统。
- (二) 引入将 PC 的操作系统及标准软件更新至最新状态的设定规则。
- (三) 引入可对所有 PC 自动应用漏洞修补程序的 IT 资产管理工具。
- (四) 禁止安装非标准软件，并强制卸载已安装的非标准软件。
- (五) 引入可对日志数据进行统一管理、分析，从而发现安全威胁的安全信息与事件管理 (SIEM) 系统。

解答群

ア (一)，(二)

イ (一)，(三)

ウ (一)，(四)

エ (一)，(五)

オ (二)，(三)

カ (二)，(四)

キ (二)，(五)

ク (三)，(四) (正确答案：现状问题是“不清楚非标准软件的使用及更新情况，部分未及时更新”。(三) 通过 IT 资产管理工具对所有 PC (含使用了非标准软件的 PC) 自动应用漏洞修补程序，可确保全部软件保持最新状态；(四) 直接禁止并强制卸载非标准软件，从根本上消除非标准软件带来的更新管理漏洞。两者组合即可使评价结果变为“已实施”)

ケ (三)，(五)

コ (四)，(五)

問52 / 问题 52 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
複数の子会社	multiple subsidiaries	多家子公司
食品メーカー	food manufacturer	食品制造商
在宅勤務	telework / working from home	在家办公
PCセキュリティ規程	PC security regulations	PC 安全规程
買収する	acquire (a company)	并购、收购
子会社にする	make into a subsidiary	变为子公司
上限を週2日とする	cap at two days per week	上限设为每周 2 天
対応状況	compliance status	应对状况
評価結果	evaluation result	评价结果
アプリケーションソフトウェア	application software	应用软件
技術的に制限する	technically restrict	技术上加以限制
外部記憶媒体	external storage media	外部存储介质
アクセスを技術的に禁止する	technically prohibit access	技术上禁止访问
Bluetooth	Bluetooth	蓝牙
NG (満たさない)	NG (does not meet requirement)	NG (不满足)
OK (満たす)	OK (meets requirement)	OK (满足)
追加対策	additional countermeasure	追加对策
情報セキュリティリスクを低減する	reduce information security risk	降低信息安全风险
NPC (在宅勤務用PC)	telework PC (NPC)	在家办公用 PC (NPC)
コピー	copy	复制、拷贝
持ち出される	be taken out	被带出
マルウェア感染する	become infected with malware	感染恶意软件

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問52 A社は、複数の子会社を持つ食品メーカーであり、在宅勤務に適用するPCセキュリティ規程（以下、A社PC規程という）を定めている。

A社は、20XX年4月1日に同業のB社を買収して子会社にした。B社は、在宅勤務できる日数の上限を週2日とした在宅勤務制度を導入しており、全ての従業員が利用している。

B社は、A社PC規程と同様の規程を作成して順守することにした。B社は、自社の規程の作成に当たり、表1のとおりA社PC規程への対応状況の評価結果を取りまとめた。

表1 A社PC規程へのB社の対応状況の評価結果（抜粋）

項番	A社PC規程	評価結果
1	(省略)	OK
2	(省略)	OK
3	会社が許可したアプリケーションソフトウェアだけを導入できるように技術的に制限すること	NG
4	外部記憶媒体へのアクセスを技術的に禁止すること	NG ¹⁾
5	Bluetoothの利用を技術的に禁止すること	NG

注記 評価結果が“OK”とはA社PC規程を満たす場合、“NG”とは満たさない場合をいう。

注¹⁾ B社は、外部記憶媒体へのアクセスのうち、外部記憶媒体に保存してあるアプリケーションソフトウェア及びファイルのNPCへのコピーだけは許可している。

評価結果のうち、A社PC規程を満たさない項番については、必要な追加対策を実施することによって、情報セキュリティリスクを低減することにした。

設問 表 1 中の項番 4 について、B 社が必要な追加対策を実施することによって低減できる情報セキュリティリスクは次のうちどれか。低減できるものだけを全て挙げた組合せを、解答群の中から選べ。ここで、項番 3, 5 への追加対策は実施しないものとする。

- (一) B 社で許可していないアプリケーションソフトウェアが保存されている外部記憶媒体が NPC に接続された場合に、当該 NPC がマルウェア感染する。
- (二) 外部記憶媒体が NPC に接続された場合に、当該外部記憶媒体に当該 NPC 内のデータを保存して持ち出される。
- (三) マルウェア付きのファイルが保存されている外部記憶媒体が NPC に接続された場合に、当該 NPC がマルウェア感染する。
- (四) マルウェアに感染している NPC に外部記憶媒体が接続された場合に、当該外部記憶媒体がマルウェア感染する。

解答群

- | | |
|-----------------|-----------------|
| ア (一), (二) | イ (一), (二), (三) |
| ウ (一), (二), (四) | エ (一), (三) |
| オ (一), (四) | カ (二), (三) |
| キ (二), (四) | ク (三), (四) |

■ 3. 原题对应中文意思

问52 A 公司是拥有多家子公司的食品制造商，制定了适用于在家办公的 PC 安全规程（以下称“A 公司 PC 规程”）。

A 公司于 20XX 年 4 月 1 日并购了同行 B 公司，使其成为子公司。B

公司此前已引入在家办公制度，规定在家办公天数上限为每周 2 天，且全体员工均在使用该制度。

B 公司决定制定与 A 公司 PC 规程相同的规程并加以遵守。B 公司在制定自身规程之际，按表1 汇总了对 A 公司 PC 规程的对应状况评价结果。

表1 B 公司对 A 公司 PC 规程的对应状况评价结果（节选）

项号 1（省略）评价结果：OK

项号 2（省略）评价结果：OK

项号 3 仅可通过技术手段限制只能安装公司许可的应用软件 评价结果：NG

项号 4 技术上禁止访问外部存储介质 评价结果：NG^{注1)}

项号 5 技术上禁止使用蓝牙（Bluetooth）评价结果：NG

注记：评价结果“OK”表示满足 A 公司 PC 规程，“NG”表示不满足。

注1) B 公司在对外部存储介质的访问限制中，仅允许将外部存储介质中保存的应用软件及文件复制到在家办公用 PC（NPC）中。

对于评价结果中不满足 A 公司 PC 规程的项号，B 公司决定通过实施必要的追加对策来降低信息安全风险。

设问 针对表1 中项号 4，B 公司通过实施必要的追加对策能够降低的信息安全风险是下列哪些？请从解答群中选出全部包含能够被降低的风险的组合。此处，假设不对项号 3、5 实施追加对策。

(一) 保存有 B 公司未许可的应用软件的外部存储介质连接到 NPC 时，该 NPC 感染恶意软件。

(二) 外部存储介质连接到 NPC 时，将该 NPC 内的数据保存到该外部存储介质中并带出。

(三) 保存有带恶意软件文件的外部存储介质连接到 NPC 时，该 NPC 感染恶意软件。

(四) 已感染恶意软件的 NPC 连接外部存储介质时，该外部存储介质感染恶意软件。

解答群

ア (一)，(二)

イ (一)，(二)，(三)

ウ (一)，(二)，(四)

エ (一)，(三)（正确答案：目前 B 公司对外部存储介质仅允许“从外部存储介质向 NPC

拷入”文件/软件这一单一方向，禁止 NPC 向外部存储介质写出数据（因此(二)带出数据、(四) NPC 感染外部介质这两种“流出”方向的风险本来就被现行的例外设置所阻断，并非本次新增对策所能降低的风险）。若对项号4 实施完全禁止外部存储介质访问的追加对策（即取消现有的拷入例外），则可以杜绝因“拷入”外部存储介质中的未许可软件(一)或带恶意软件的文件(三)而导致 NPC 感染恶意软件的风险，因此可被降低的风险为(一)和(三)）

オ (一)，(四)

カ (二)，(三)

キ (二)，(四)

ク (三)，(四)

問53 / 问题 53 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
高級家具	high-end furniture	高级家具
通信販売	mail-order / online retail	通信销售、邮购
新規事業	new business	新业务
個人情報	personal information	个人信息
複合機	multifunction printer	复合机 (多功能一体机)
送り状	shipping label / invoice	运单、发货单
通販事業部エリア	mail-order division area	邮购事业部区域
ICカード認証	IC card authentication	IC 卡认证
解錠する	unlock	解锁
入退室できる	can enter and exit a room	可以出入房间
オフィスのレイアウト	office layout	办公室布局
会議室	meeting room	会议室
ショールーム	showroom	展示厅
卸事業部エリア	wholesale division area	批发事业部区域
共用エリア	shared area	共用区域
受付エリア	reception area	前台接待区域
自動ドア	automatic door	自动门
正門	main entrance	正门
ICカードリーダー	IC card reader	IC 卡读卡器
防犯設備操作盤	security equipment control panel	防犯设备操作盘
共連れ	tailgating	尾随、共同进入 (共连带)
改善案	improvement plan	改善方案
監視カメラ	surveillance camera	监控摄像头
標語を掲示する	post a slogan	张贴标语
AESの暗号方式	AES encryption scheme	AES 加密方式
指静脈認証	finger vein authentication	指静脉认证
アンチパスバック	anti-passback	反潜回 (Anti-passback)
従業員証	employee ID badge	员工证
携帯する	carry	随身携带
個別に注意する	individually caution	个别提醒

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問53 A社は、高級家具を販売する企業である。A社は2年前に消費者に直接通信販売する新規事業を開始した。それまでA社は、個人情報ほとんど取り扱っていなかったが、通信販売事業を開始したことによって、複合機で印刷した送り状など、顧客の個人情報を大量に扱うようになってきた。そのため、オフィス内に通販事業部エリアを設け、個人情報が漏えいしないよう対策した。具体的には、通販事業部エリアの出入口に、ICカード認証でドアを解錠するシステムを設置し、通販事業部の従業員だけが通販事業部エリアに入退室できるようにした。他のエリアはA社の全従業員が自由に利用できるようにしている。図1は、A社のオフィスのレイアウトである。

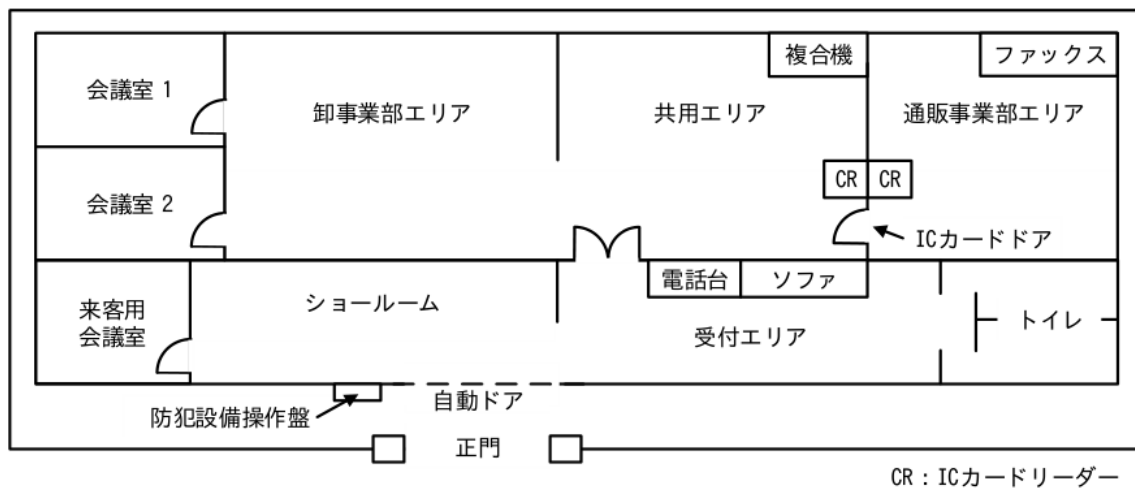


図1 A社のオフィスのレイアウト

このレイアウトでの業務を観察したところ、通販事業部エリアへの入室時に、A社の従業員同士による共連れが行われているという問題点が発見され、改善案を考えることになった。

設問 改善案として適切なものだけを全て挙げた組合せを，解答群の中から選べ。

- (一) IC カードドアに監視カメラを設置し，1 年に 1 回監視カメラの映像をチェックする。
- (二) IC カードドアの脇に，共連れのもたらすリスクを知らせる標語を掲示する。
- (三) IC カードドアを，AES の暗号方式を用いたものに変更する。
- (四) IC カードの認証に加えて指静脈認証も行うようにする。
- (五) 正門内側の自動ドアに共連れ防止用のアンチパスバックを導入する。
- (六) 通販事業部エリア内では，従業員証を常に見えるところに携帯する。
- (七) 共連れを発見した場合は従業員同士で個別に注意する。

解答群

- | | | |
|-----------|-----------|-----------|
| ア (一)，(二) | イ (一)，(四) | ウ (一)，(五) |
| エ (二)，(三) | オ (二)，(七) | カ (三)，(六) |
| キ (三)，(七) | ク (四)，(六) | ケ (五)，(六) |
| コ (五)，(七) | | |

■ 3. 原题对应中文意思

问53 A 公司是一家销售高级家具的企业。A 公司在 2 年前开始了面向消费者的直接邮购新业务。在此之前，A 公司几乎不涉及个人信息，但开展邮购业务后，因复合机打印发货单等原因，开始大量处理顾客的个人信息。为此，公司在办公室内设立了邮购事业部区域，并采取对策防止个人信息泄露。具体而言，在邮购事业部区域的出入口设置了通过 IC 卡认证解锁门禁的系统，只允许邮购事业部的员工出入该区域。其他区域则由 A 公司全体员工自由使用。图1 为 A 公司的办公室布局。

图1 A 公司办公室布局

(由左至右、由上至下依次为：) 会议室1、卸货事业部区域 (中间为共用区域，设有复合机及传真机)、邮购事业部区域；会议室2；来访接待会议室、展示厅 (Showroom)、电话台与沙发、 (IC 卡读卡器×2) 通往邮购事业部区域的 IC 卡门；受理接待区域、卫生间；防犯设备操作盘、自动门、正门。注：CR = IC 卡读卡器。

对该布局下的业务进行观察后发现，在进入邮购事业部区域时，存在 A 公司员工之间互相“尾随共同进入 (共連れ)”的问题，因此需要考虑改善方案。

设问 请从解答群中选出全部包含恰当改善方案的组合。

- (一) 在 IC 卡门处设置监控摄像头，每年检查 1 次监控录像。
- (二) 在 IC 卡门旁张贴告知“尾随共同进入”所带来风险的标语。
- (三) 将 IC 卡门更换为采用 AES 加密方式的产品。
- (四) 在 IC 卡认证的基础上，追加指静脉认证。
- (五) 在正门内侧的自动门上引入防尾随共同进入用的反潜回 (Anti-passback) 系统。
- (六) 在邮购事业部区域内，要求员工始终将员工证佩戴在显眼位置。
- (七) 发现尾随共同进入的情况时，由员工之间个别提醒。

解答群

ア (一)，(二)

イ (一)，(四)

ウ (一)，(五)

エ (二)，(三)

オ (二)，(七) (正确答案：本案例中的问题根源是“A 公司自家员工之间”的相互尾随共同进入，属于员工安全意识、习惯层面的问题，而非外部入侵或加密强度不足等技术问题。(二) 通过张贴标语提高全员对尾随风险的认知，(七) 通过员工间相互提醒形成日常监督机制，两者均属于针对性强、成本低且能直接从源头改变员工行为的有效对策，因此为恰当组合)

カ (三)，(六)

キ (三)，(七)

ク (四)，(六)

ケ (五)，(六)

コ (五)，(七)

問54 / 问题 54 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
旅行商品	travel products	旅游商品
顧客情報	customer information	顾客信息
ファイルサーバ	file server	文件服务器
磁気テープ	magnetic tape	磁带
バックアップ	backup	备份
世代	generation (of backups)	代 (备份代数)
キャビネット	cabinet	柜子
保管される	be stored	被保管
情報セキュリティリーダー	information security leader	信息安全负责人
リスクの見直し	risk review	风险复核
ランサムウェア	ransomware	勒索软件
データが暗号化される	data is encrypted (by an attacker)	数据被 (攻击者) 加密
最新のデータが利用できなくなる	the latest data becomes unavailable	最新数据无法使用
更新情報が失われる	updated information is lost	更新信息丢失
より低減する	reduce further	进一步降低
高速な製品に交換する	replace with a faster product	更换为更高速的产品
ハードディスク	hard disk	硬盘
二組み取得する	take two sets (of backups)	取得两组 (备份)
遠隔地に保管する	store at a remote location	保管在异地
マルウェア対策ソフト	anti-malware software	反恶意软件 (杀毒) 软件

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問54 A社は旅行商品を販売しており、業務の中で顧客情報を取り扱っている。A社が保有する顧客情報は、A社のファイルサーバ1台に保存されている。ファイルサーバは、顧客情報を含むフォルダにある全てのファイルを磁気テープに毎週土曜日にバックアップするよう設定されている。バックアップは2世代分が保存され、ファイルサーバの隣にあるキャビネットに保管されている。

A社では年に一度、情報セキュリティに関するリスクの見直しを実施している。情報セキュリティリーダーであるE主任は、A社のデータ保管に関するリスクを見直して図1にまとめた。

- | |
|---|
| <ol style="list-style-type: none">1. ランサムウェアによってデータが暗号化され、最新のデータが利用できなくなることによって、最大1週間分の更新情報が失われる。2. (省略)3. (省略)4. (省略) |
|---|

図1 A社のデータ保管に関するリスク（抜粋）

E主任は、図1の1に関するリスクを現在の対策よりも、より低減するための対策を検討した。

設問 E主任が検討した対策はどれか。解答群のうち、最も適切なものを選べ。

解答群

ア 週1回バックアップを取得する代わりに、毎日1回バックアップを取得して7世代分保存する。

イ バックアップ後に磁気テープの中のファイルのリストと、ファイルサーバのバックアップ対象フォルダ中のファイルのリストを比較し、差分がないことを確認する。

ウ バックアップに利用する磁気テープ装置を、より高速な製品に交換する。

エ バックアップ用の媒体を磁気テープからハードディスクに変更する。

オ バックアップを二組み取得し、うち一組みを遠隔地に保管する。

カ ファイルサーバにマルウェア対策ソフトを導入する。

■ 3. 原题对应中文意思

问54 A 公司经营旅游商品销售，业务中会处理顾客信息。A 公司所持有的顾客信息保存在一台文件服务器中。该文件服务器设定为每周六将包含顾客信息的文件夹中的所有文件备份至磁带。备份保留 2 代，保管在文件服务器旁边的柜子中。

A 公司每年进行一次信息安全相关的风险复核。担任信息安全负责人的 E 主任对 A 公司数据保管相关的风险进行了复核，并汇总为图1。

图1 A 公司数据保管相关风险（节选）

1. 因遭受勒索软件攻击导致数据被加密、最新数据无法使用，最多可能损失 1 周的更新信息。
2. （省略）
3. （省略）
4. （省略）

E 主任针对图1 中第 1 项风险，研究了比现行对策能够进一步降低风险的方案。

设问 E 主任所研究的对策是下列哪一项？请从解答群中选出最恰当的一项。

解答群

ア 将每周 1 次的备份改为每天 1 次，并保留 7

代备份。（正确答案：现行方案每周备份一次，一旦遭遇勒索软件攻击，最坏情况下会丢失长达 1 周的更新数据；改为每天备份并保留 7 代，可将最大数据丢失窗口从 1 周缩短至 1 天，直接针对“最多丢失 1 周更新信息”这一风险点进行改善）

イ 备份完成后，将磁带中的文件列表与文件服务器备份对象文件夹中的文件列表进行比对，确认二者没有差异。

ウ 将用于备份的磁带装置更换为速度更快的产品。

エ 将备份介质从磁带更改为硬盘。

オ 取得两组备份，将其中一组保管在异地。

カ 在文件服务器上安装反恶意软件（杀毒）软件。

問55 / 问题 55 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
SaaS形式	SaaS-based	SaaS 形式
給与計算サービス	payroll calculation service	薪资计算服务
法人向けに提供する	provide to corporate clients	面向法人 (企业) 提供
アカウント	account	账户
ログイン画面	login screen	登录界面
利用者ID及びパスワード	user ID and password	用户 ID 及密码
賞与	bonus	奖金
ロックされる	become locked	被锁定
ロックを解除する	unlock	解除锁定
解除画面で申請する	apply via the unlock screen	在解锁界面申请
標的型攻撃メール	targeted attack email	定向攻击邮件 (鱼叉式钓鱼邮件)
対応訓練	response training / drill	应对演练
経営会議	management meeting	经营会议
送信者メールアドレス	sender email address	发件人邮箱地址
ドメインを装う	impersonate a domain	伪装成某域名
偽解除サイト	fake unlock site	伪造解锁网站
氏名，所属部門名	name, department name	姓名、所属部门名称
入力させる	make (someone) input	使其输入
結果の報告	reporting of results	结果报告
個人情報としている	be treated as personal information	作为个人信息对待
想定している	assume / envision	设想、假定

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問55 A社は、SaaS形式の給与計算サービス（以下、Aサービスという）を法人向けに提供する、従業員100名のIT会社である。A社は、自社でもAサービスを利用している。A社の従業員は、WebブラウザでAサービスのログイン画面にアクセスし、Aサービスのアカウント（以下、Aアカウントという）の利用者ID及びパスワードを入力する。ログインに成功すると、自分の給与及び賞与の確認、パスワードの変更などができる。利用者IDは、個人ごとに付与した不規則な8桁の番号である。ログイン時にパスワードを連続して5回間違えるとAアカウントはロックされる。ロックを解除するためには、Aサービスの解除画面で申請する。

A社は、半年に1回、標的型攻撃メールへの対応訓練（以下、H訓練という）を実施しており、表1に示す20XX年下期のH訓練計画案が経営会議に提出された。

表1 20XX年下期のH訓練計画案（抜粋）

項目	内容
電子メールの送信日時	次の日時に、H訓練の電子メールを全従業員宛に送信する。 ・20XX年10月1日 10時00分
送信者メールアドレス	Aサービスを装ったドメインのメールアドレス
電子メールの本文	次を含める。 ・Aアカウントはロックされていること ・ロックを解除するには、次のURLにアクセスすること ・偽解除サイトのURL
偽解除サイト	・氏名、所属部門名並びにAアカウントの利用者ID及びパスワードを入力させる。 ・全ての項目の入力が完了すると、H訓練であることを表示する。
結果の報告	経営会議への報告予定日：20XX年10月31日

注記 偽解除サイトで入力された情報は、保存しない。A社は、従業員の氏名、所属部門名及びAアカウントの情報を個人情報としている。

経営会議では、表1の計画案はどのような標的型攻撃メールを想定しているのかという質問があった。

設問 表 1 の計画案が想定している標的型攻撃メールはどれか。解答群のうち、最も適切なものを選べ。

解答群

- ア 従業員を A サービスに誘導し、A アカウントのロックが解除されるかを試行する標的型攻撃メール
- イ 従業員を攻撃者が用意した Web サイトに誘導し、A アカウントがロックされない連続失敗回数の上限を発見する標的型攻撃メール
- ウ 従業員を攻撃者が用意した Web サイトに誘導し、従業員の個人情報を不正に取得する標的型攻撃メール
- エ 複数の従業員を A サービスに同時に誘導し、アクセスを集中させることによって、一定期間、A サービスを利用不可にする標的型攻撃メール

■ 3. 原题对应中文意思

问55 A 公司是一家从事 SaaS 形式薪资计算服务（以下称“A 服务”）的 IT 企业，面向法人客户提供该服务，员工共 100 名。A 公司自身也在使用 A 服务。A 公司员工通过 Web 浏览器访问 A 服务的登录界面，输入 A 服务账户（以下称“A 账户”）的用户 ID 及密码。登录成功后，可查看自己的工资及奖金、修改密码等。用户 ID 是按个人分配的不规则 8 位数字编号。登录时若连续 5 次输错密码，则该 A 账户将被锁定。如需解除锁定，需在 A 服务的解锁界面上提出申请。

A 公司每半年开展一次针对定向攻击邮件的应对演练（以下称“H 演练”），表1 所示的 20XX 年下半年 H 演练计划方案已提交经营会议。

表1 20XX 年下半年 H 演练计划方案（节选）

项目：电子邮件发送日期与时间 内容：在下列日期时间，向全体员工发送 H 演练邮件：20XX 年 10 月 1 日 10 点 00 分

项目：发件人邮箱地址 内容：伪装成 A 服务所属域名的邮箱地址

项目：邮件正文 内容：包含以下内容：A 账户已被锁定；如需解除锁定，请访问以下 URL：伪解除网站的 URL

项目：伪解除网站 内容：要求输入姓名、所属部门名称，以及 A 账户的用户 ID

与密码；全部项目填写完成后，会显示这是一次 H 演练

项目：结果报告 内容：预计于 20XX 年 10 月 31 日向经营会议报告结果

注记：伪解除网站中输入的信息不会被保存。A 公司将员工的姓名、所属部门名称及 A 账户信息视为个人信息。

在经营会议上，有人提出疑问：表1 所示计划方案究竟设想的是何种定向攻击邮件？

设问 表1 所示计划方案所设想的定向攻击邮件是下列哪一项？请从解答群中选出最恰当的一项。

解答群

ア 将员工诱导至 A 服务，试探 A 账户的锁定是否会被解除的定向攻击邮件。

イ 将员工诱导至攻击者准备的网站，探测使 A 账户不会被锁定的连续失败次数上限的定向攻击邮件。

ウ

将员工诱导至攻击者准备的网站，非法获取员工个人信息的定向攻击邮件。（正确答案：该演练邮件正文诱导员工点击 URL 访问伪造的解锁网站，并在该网站上输入姓名、所属部门及账户

ID/密码等个人信息，整个设计正是模拟攻击者通过钓鱼网站骗取员工个人信息这一手法）

エ 同时将多名员工诱导至 A 服务，通过使访问集中而在一定时期内导致 A 服务无法使用的定向攻击邮件。

問56 / 问题 56 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
学習塾	cram school / tutoring school	补习班 (学习塾)
校舎	school building / branch	校舍、分校
教務部	academic affairs department	教务部
情報システム部	IT department	信息系统部
監査部	audit department	监察部 (审计部)
塾生	school student (of the cram school)	塾生 (补习班学生)
個人データ	personal data	个人数据
塾生管理システム	student management system	塾生管理系统
システム管理	system administration	系统管理
入塾	enrollment	入塾 (入学)
退塾	withdrawal (from the school)	退塾 (退学)
プロフィールの編集	profile editing	资料编辑
模試結果	mock exam results	模拟考试成绩
進学先	school of advancement	升学去向
共用端末	shared terminal	共用终端
利用者ID	user ID	用户 ID
参照権限	read (view) permission	查阅权限
更新権限	update permission	更新权限
アクセス権限	access permission	访问权限
端末ID	terminal ID	终端 ID
内部監査	internal audit	内部审计
Webブラウザに保存する	save in the web browser	保存在 Web 浏览器中
情報セキュリティリスクが存在する	an information security risk exists	存在信息安全风险
不正にアクセスされる	be accessed without authorization	被非法访问

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問56 A社は学習塾を営んでいる会社であり、全国に50の校舎を展開している。A社には、教務部、情報システム部、監査部などがある。学習塾に通う又は通っていた生徒（以下、塾生という）の個人データは、学習塾向けの管理システム（以下、塾生管理システムという）に格納している。塾生管理システムのシステム管理は情報システム部が行っている。塾生の個人データ管理業務と塾生管理システムの概要を図1に示す。

- ・教務部員は、入塾した塾生及び退塾する塾生の登録、塾生プロフィールの編集、模試結果の登録、進学先の登録など、塾生の個人データの入力、参照及び更新を行う。
- ・教務部員が使用する端末は教務部の共用端末である。
- ・塾生管理システムへのログインには利用者IDとパスワードを利用する。
- ・利用者IDは個人別に発行されており、利用者IDの共用はしていない。
- ・塾生管理システムの利用者のアクセス権限には参照権限及び更新権限の2種類がある。参照権限があると塾生の個人データを参照できる。更新権限があると塾生の個人データの参照、入力及び更新ができる。アクセス権限は塾生の個人データごとに設定できる。
- ・教務部員は、担当する塾生の個人データの更新権限をもっている。担当しない塾生の個人データの参照権限及び更新権限はもっていない。
- ・共用端末のOSへのログインには、共用端末の識別子（以下、端末IDという）とパスワードを利用する。
- ・共用端末のパスワード及び塾生管理システムの利用者のアクセス権限は情報システム部が設定、変更できる。

図1 塾生の個人データ管理業務と塾生管理システムの概要

教務部は、今年実施の監査部による内部監査の結果、Webブラウザに塾生管理システムの利用者IDとパスワードを保存しており、情報セキュリティリスクが存在するとの指摘を受けた。

設問 監査部から指摘された情報セキュリティリスクはどれか。解答群のうち、最も適切なものを選べ。

解答群

- ア 共用端末と塾生管理システム間の通信が盗聴される。
- イ 共用端末が不正に持ち出される。
- ウ 情報システム部員によって塾生管理システムの利用者のアクセス権限が不正に変更される。
- エ 教務部員によって共用端末のパスワードが不正に変更される。
- オ 塾生の個人データがアクセス権限をもたない教務部員によって不正にアクセスされる。

■ 3. 原题对应中文意思

问56 A 公司经营学习塾（补习班），在全国展开 50 所校舍。A 公司设有教务部、信息系统部、监察部等部门。正在或曾经就读于本补习班的学生（以下称“塾生”）的个人数据，保存在面向补习班的管理系统（以下称“塾生管理系统”）中。塾生管理系统的系统管理由信息系统部负责。塾生个人数据管理业务及塾生管理系统概要如图1 所示。

图1 塾生个人数据管理业务与塾生管理系统概要

- 教务部员工负责办理入塾及退塾塾生的登记、塾生资料的编辑、模拟考试成绩的登记、升学去向的登记等塾生个人数据的录入、查阅及更新。
- 教务部员工所使用的终端为教务部的共用终端。
- 登录塾生管理系统需使用用户 ID 和密码。
- 用户 ID 按个人分别签发，不存在共用用户 ID 的情况。
- 塾生管理系统的用户访问权限分为查阅权限和更新权限两种。拥有查阅权限即可查阅塾生的个人数据；拥有更新权限则可查阅、录入及更新塾生的个人数据。访问权限可按塾生个人数据逐一设置。
- 教务部员工拥有其所负责塾生的个人数据的更新权限；对于非本人负责的塾生的个人数据，则既无查阅权限，也无更新权限。
- 登录共用终端的操作系统，需使用共用终端的识别号（以下称“终端 ID”）和密码。
- 共用终端的密码，以及塾生管理系统用户的访问权限，均可由信息系统部进行设置与变更。

教务部在本年度监察部实施的内部审计中，被指出在 Web 浏览器中保存了塾生管理系统的用户 ID 和密码，存在信息安全风险。

设问 监察部所指出的信息安全风险是下列哪一项？请从解答群中选出最恰当的一项。

解答群

ア 共用终端与塾生管理系统之间的通信被窃听。

イ 共用终端被非法带出。

ウ 信息系统部员工非法变更了塾生管理系统用户的访问权限。

エ 教务部员工非法变更了共用终端的密码。

オ 塾生的个人数据被不具备访问权限的教务部员工非法访问。（正确答案：由于用户 ID 和密码被保存在教务部共用终端的浏览器中，任何使用该共用终端的教务部员工，都可能在无需重新输入密码的情况下，直接以浏览器中保存的其他同事账号自动登录，从而查阅或更新自己原本没有访问权限的塾生个人数据，这正是共用终端保存登录凭据所带来的越权访问风险）

問57 / 问题 57 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
投資コンサルティング会社	investment consulting company	投资咨询公司
管理部門	administrative departments	管理部门
支店	branch office	分公司、分店
運用管理する	operate and manage	运营管理
最小権限の原則	principle of least privilege	最小权限原则
ヒアリングを行う	conduct interviews	进行访谈
自己評価の実施	conducting self-assessment	开展自我评价
自己評価シート	self-assessment sheet	自我评价表
配布する	distribute	分发
職場の状況を観察する	observe the workplace situation	观察工作现场状况
判定ルール	judgment rule	判定规则
代替コントロール	compensating control	替代性控制措施 (补偿性控制)
同程度にリスクが低減されている	risk is reduced to a comparable degree	风险被降低到同等程度
評価根拠	basis for evaluation	评价依据
リスクが抑えられていない	risk is not sufficiently mitigated	风险未被充分抑制
リスクがそもそも存在しない	the risk does not exist in the first place	该风险本身并不存在
設定状況が適切である	the configuration status is appropriate	设置状况恰当
従業員600名	600 employees	600 名员工
東京の本社	Tokyo head office	东京总公司
関西	Kansai region	关西地区
一時的に保存する	temporarily store	临时保存

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問57 A社は従業員600名の投資コンサルティング会社である。東京の本社には、情報システム部、監査部などの管理部門があり、関西にB支店がある。B支店の従業員は10名である。

B支店では、情報システム部が運用管理しているファイルサーバを使用しており、顧客情報を含むファイルを一時的に保存する場合がある。その場合、ファイルのアクセス権は、当該ファイルを保存した従業員が最小権限の原則に基づいて設定する。今年、B支店では、従業員にヒアリングを行い、ファイルのアクセス権がそのとおりに設定されていることを確認した。

〔自己評価の実施〕

A社では、1年に1回、監査部が各部門に、評価項目を記載したシート（以下、自己評価シートという）を配布し、自己評価の実施と結果の提出を依頼している。

B支店で情報セキュリティリーダーを務めるC氏は、監査部から送付されてきた自己評価シートに従って、職場の状況を観察したり、従業員にヒアリングしたりして評価した。自己評価シートの評価結果は図1の判定ルールに従って記入する。C氏が作成したB支店の評価結果を表1に示す。

- ・評価項目どおりに実施している場合：“OK”
- ・評価項目どおりには実施していないが、代替コントロールによって、“OK”の場合と同程度にリスクが低減されていると考えられる場合：“(OK)”（代替コントロールを具体的に評価根拠欄に記入する。）
- ・評価項目どおりには実施しておらず、かつ、代替コントロールによって評価項目に関するリスクが抑えられていないと考えられる場合：“NG”
- ・評価項目に関するリスクがそもそも存在しない場合：“NA”

図1 評価結果の判定ルール

表1 B支店の評価結果（抜粋）

No.	評価項目	評価結果	評価根拠
10	(省略)	OK	(省略)
19	ファイルサーバ上の顧客情報のアクセス権は最小権限の原則に基づいて設定されている。	a	
25	(省略)	OK	(省略)

設問 表 1 中の

a

 に入れる字句はどれか。解答群のうち、最も適切なものを選び。

a に関する解答群

	評価結果	評価根拠
ア	OK	アクセス権の設定状況が適切であることを確認した。
イ	OK	アクセス権を適切に設定するルールが存在することを確認した。
ウ	OK	ファイルサーバは情報システム部が運用管理している。
エ	NA	顧客情報をファイルサーバに保存することは禁止されている。

■ 3. 原题对应中文意思

问57 A 公司是拥有 600 名员工的投资咨询公司。位于东京的总公司设有信息系统部、监察部等管理部门，在关西地区设有 B 分公司。B 分公司员工共 10 名。

B 分公司使用由信息系统部负责运营管理的文件服务器，有时会临时保存包含顾客信息的文件。此种情况下，文件的访问权限由保存该文件的员工依据最小权限原则进行设置。今年，B 分公司对员工进行了访谈，确认文件的访问权限确实按照该原则进行了设置。

【自我评价的实施】

A 公司每年 1 次，由监察部向各部门发放记载有评价项目的表格（以下称“自我评价表”），要求各部门开展自我评价并提交结果。

在 B 分公司担任信息安全负责人的 C 先生，依照监察部送来的自我评价表，通过观察工作现场情况、对员工进行访谈等方式进行评价。自我评价表的评价结果按图1 所示的判定规则填写。C 先生所制作的 B 分公司评价结果如表1 所示。

图1 评价结果的判定规则

- 按照评价项目实际执行的情形：“OK”
- 未按照评价项目执行，但通过替代性控制措施使风险降低到与“OK”同等程度的情形：“(OK)”（需在评价依据栏中具体记载该替代性控制措施）
- 既未按照评价项目执行，替代性控制措施也未能抑制该评价项目相关风险的情形：“NG”
- 该评价项目相关的风险本身并不存在的情形：“NA”

表1 B 分公司评价结果（节选）

编号 10（省略）评价结果：OK 评价依据：（省略）
编号 19 文件服务器上顾客信息的访问权限，是依据最小权限原则设置的 评价结果：a 评价依据：a
编号 25（省略）评价结果：OK 评价依据：（省略）

设问 表1 中 a 处应填入的内容是下列哪一项？请从关于 a 的解答群中选出最恰当的一项。

关于 a 的解答群

评价结果 评价依据

- ア OK 确认了访问权限的设置状况是恰当的。（正确答案：案例正文中已说明“今年，B 分公司对员工进行了访谈，确认文件的访问权限确实按照最小权限原则设置”，即通过实际访谈/观察确认了访问权限设置状况本身是恰当的，这正符合“OK”——按评价项目实际执行——的判定标准）
- イ OK 确认了存在按恰当方式设置访问权限的规则。
- ウ OK 文件服务器由信息系统部负责运营管理。
- エ NA 禁止将顾客信息保存到文件服务器中。

問58 / 问题 58 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
国内外に複数の子会社をもつ	having multiple subsidiaries at home and abroad	在国内外拥有多家子公司
インターネットに公開する	publish on the Internet	公开在互联网上
脆弱性診断基準	vulnerability diagnosis standard	脆弱性诊断基准
会員向けに	for members	面向会员
製品を販売するWebサイト	product sales website	销售产品的网站
会員情報	member information	会员信息
自己点検を実施する	conduct a self-inspection	开展自我检查
Webアプリケーションプログラム	web application program	Web 应用程序
脆弱性診断の実施	conducting vulnerability diagnosis	实施脆弱性诊断
新規開発時	at the time of new development	新开发时
機能追加時	at the time of feature addition	功能追加时
ミドルウェア	middleware	中间件
軽微な脆弱性	minor vulnerability	轻微脆弱性
検出された	was detected	被检测出
脆弱性診断結果の報告	reporting of vulnerability diagnosis results	脆弱性诊断结果的报告
情報セキュリティ委員会	Information Security Committee	信息安全委员会
脆弱性診断結果の対応	response to vulnerability diagnosis results	脆弱性诊断结果的应对
緊急を要する脆弱性	vulnerability requiring urgent response	需紧急处理的脆弱性
速やかに対応する	respond promptly	尽快应对
指定された期限	the specified deadline	指定的期限
最高情報セキュリティ責任者 (CISO)	Chief Information Security Officer (CISO)	首席信息安全官 (CISO)
承認を得る	obtain approval	获得批准
恒久的な対策	permanent countermeasure	永久性对策
暫定対策	temporary/interim countermeasure	临时性对策
更改時	at the time of system renewal	系统更新换代时

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問58 国内外に複数の子会社をもつ A 社では、インターネットに公開する Web サイトについて、A 社グループの脆弱性診断基準（以下、A 社グループ基準という）を設けている。A 社の子会社である B 社は、会員向けに製品を販売する Web サイト（以下、B 社サイトという）を運営している。B 社サイトは、会員だけが B 社の製品やサービスを検索できる。会員の氏名、メールアドレスなどの会員情報も管理している。

B 社では、11 月に情報セキュリティ活動の一環として、A 社グループ基準を基に自己点検を実施し、その結果を表 1 のとおりまとめた。

表 1 B 社自己点検結果（抜粋）

項番	点検項目	A 社グループ基準	点検結果
(一)	Web アプリケーションプログラム（以下、Web アプリという）に対する脆弱性診断の実施	・ インターネットに公開している Web サイトについて、Web アプリの新規開発時、及び機能追加時に行う。 ・ 機能追加などの変更がない場合でも、年 1 回以上行う。	・ 3 年前に B 社サイトをリリースする 1 か月前に、Web アプリに対する脆弱性診断を行った。リリース以降は実施していない。 ・ 3 年前の脆弱性診断では、軽微な脆弱性が 2 件検出された。
(二)	OS 及びミドルウェアに対する脆弱性診断の実施	・ インターネットに公開している Web サイトについて、年 1 回以上行う。	・ 毎年 4 月及び 10 月に、B 社サイトに対して行っている。 ・ 今年 4 月の脆弱性診断では、脆弱性が 3 件検出された。
(三)	脆弱性診断結果の報告	・ Web アプリ、OS 及びミドルウェアに対する脆弱性診断を行った場合、その結果を、診断後 2 か月以内に各社の情報セキュリティ委員会に報告する。	・ 3 年前に Web アプリに対する脆弱性診断を行った 2 週間後に、結果を情報セキュリティ委員会に報告した。 ・ OS 及びミドルウェアに対する脆弱性診断の結果は、4 月と 10 月それぞれの月末の情報セキュリティ委員会に報告した。
(四)	脆弱性診断結果の対応	・ Web アプリ、OS 及びミドルウェアに対する脆弱性診断で、脆弱性が発見された場合、緊急を要する脆弱性については、速やかに対応し、その他の脆弱性については、診断後、1 か月以内に対応する。指定された期限までの対応が困難な場合、対応の時期を明確にし、最高情報セキュリティ責任者（CISO）の承認を得る。	・ 3 年前に検出した Web アプリの脆弱性 2 件について、B 社サイトのリリースの 1 週間前に対応した。 ・ 今年 4 月に検出した OS 及びミドルウェアに対する脆弱性のうち、2 件は翌日に対応した。残り 1 件は、恒久的な対策は来年 1 月の B 社サイトの更改時に対応するものとし、それまでは、設定変更による暫定対策をとるという対応計画について、脆弱性診断の 10 日後に CISO の承認を得た。

設問 表 1 中の自己点検の結果のうち、A 社グループ基準を満たす項番だけを全て挙げた組合せを、解答群の中から選べ。

解答群

- | | |
|----------------------|-----------------|
| ア (一), (二) | イ (一), (二), (三) |
| ウ (一), (二), (三), (四) | エ (一), (二), (四) |
| オ (一), (三), (四) | カ (一), (四) |
| キ (二), (三) | ク (二), (三), (四) |
| ケ (三), (四) | |

■ 3. 原题对应中文意思

问58 在国内外拥有多家子公司的 A 公司，针对公开在互联网上的网站，制定了 A 公司集团的脆弱性诊断基准（以下称“A 公司集团基准”）。A 公司的子公司 B 公司运营着面向会员销售产品的网站（以下称“B 公司网站”）。B 公司网站仅允许会员搜索 B 公司的产品或服务，同时也管理着会员的姓名、邮箱地址等会员信息。

B 公司于 11 月作为信息安全活动的一环，依据 A 公司集团基准开展了自我检查，并将结果汇总为表1。

表1 B 公司自我检查结果（节选）

项号(一)：Web 应用程序脆弱性诊断的实施

A 公司集团基准：针对公开在互联网上的网站，须在 Web

应用程序新开发时及功能追加时进行诊断；即使没有功能追加等变更，也须每年至少进行 1 次。

点检结果：3 年前在 B 公司网站上线前 1 个月，对 Web 应用程序进行过一次脆弱性诊断，上线后再未实施过。3 年前的脆弱性诊断中，检测出 2 项轻微脆弱性。

项号(二)：操作系统及中间件脆弱性诊断的实施

A 公司集团基准：针对公开在互联网上的网站，须每年至少进行 1 次。

点检结果：每年 4 月及 10 月都会对 B 公司网站进行诊断。今年 4 月的脆弱性诊断中，检测出 3 项脆弱性。

项号(三)：脆弱性诊断结果的报告

A 公司集团基准：对 Web 应用程序、操作系统及中间件进行脆弱性诊断后，须在诊断后 2 个月以内向各公司的信息安全委员会报告结果。

点检结果：3 年前对 Web 应用程序进行脆弱性诊断的 2

周后，向信息安全委员会报告了结果。操作系统及中间件的脆弱性诊断结果，已分别在 4 月和 10 月的月末信息安全委员会上报告。

项号(四)：脆弱性诊断结果的应对

A 公司集团基准：对 Web

应用程序、操作系统及中间件的脆弱性诊断中若发现脆弱性，需紧急处理的脆弱性应尽快应对，其他脆弱性应在诊断后 1 个月以内应对；若难以在指定期限内完成应对，须明确应对时期，并取得首席信息安全官（CISO）的批准。

点检结果：3 年前检测出的 2 项 Web 应用程序脆弱性，在 B 公司网站上线前 1 周完成了应对。今年 4

月检测出的操作系统及中间件脆弱性中，有 2 项已于次日完成应对；剩余 1 项，计划在明年 1 月 B

公司网站更新换代时进行永久性对策，在此之前先采取变更设置的临时性对策，该应对计划已在脆弱性诊断 10 天后获得 CISO 的批准。

设问 表1 中的自我检查结果中，满足 A 公司集团基准的项号，请从解答群中选出全部包含所有满足项的组合。

解答群

ア (一)，(二)

イ (一)，(二)，(三)

ウ (一)，(二)，(三)，(四)

エ (一)，(二)，(四)

オ (一)，(三)，(四)

カ (一)，(四)

キ (二)，(三)

ク (二)，(三)，(四)（正确答案：项号(一)不满足，因为基准要求即使无功能变更也须每年至少诊断 1 次，而 B

公司网站自 3 年前上线后就再未进行过 Web 应用诊断；项号(二)满足，每年 4 月、10 月各诊断 1 次，达到每年至少 1 次的要求；项号(三)满足，Web 应用诊断结果在 2 周后报告（未超过 2

个月），操作系统/中间件诊断结果也在月末（未超过 2 个月）完成报告；项号(四)满足，2 件轻微脆弱性在上线前 1

周内完成应对，操作系统/中间件的脆弱性中 2 件次日修复，剩余 1 件虽未在 1 个月内彻底解决，但已采取临时对策并在 10 天内取得 CISO 批准，符合基准中“难以按期完成时经 CISO 批准”的例外规定。因此满足基准的项号为(二)(三)(四)

ケ (三)，(四)

問59 / 问题 59 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
通信販売業者	mail-order retailer	邮购零售商
生活雑貨	household goods / sundries	生活杂货
ギフト商品	gift items	礼品
担当している	be in charge of	负责
受注管理業務	order management operations	受单管理业务
問合せ対応業務	inquiry response operations	咨询应对业务
受注管理システム (Jシステム)	order management system (System J)	受单管理系统 (J 系统)
販売担当者	sales representative	销售负责人 (业务担当)
販売責任者	sales manager	销售主管 (责任人)
承認を依頼する	request approval	请求批准
突き合わせて確認する	cross-check and confirm	核对确认
差し戻す	send back / reject	打回、退回
操作権限	operation privilege	操作权限
利用方針	usage policy	使用方针
委託する	outsource	委托
入力作業	input work	录入作业
チェックする	check	核查
要求事項	requirements	要求事项
閲覧	viewing	浏览、查阅
入力	input	录入
承認	approval	审批

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問59 A社は従業員200名の通信販売業者である。一般消費者向けに生活雑貨、ギフト商品などの販売を手掛けている。取扱商品の一つである商品Zは、Z販売課が担当している。

〔Z販売課の業務〕

現在、Z販売課の要員は、商品Zについての受注管理業務及び問合せ対応業務を行っている。商品Zについての受注管理業務の手順を図1に示す。

商品Zの顧客からの注文は電子メールで届く。

(1) 入力

販売担当者は、届いた注文（変更、キャンセルを含む）の内容を受注管理システム¹⁾（以下、Jシステムという）に入力し、販売責任者²⁾に承認を依頼する。

(2) 承認

販売責任者は、注文の内容とJシステムへの入力結果を突き合わせて確認し、問題がなければ承認する。問題があれば差し戻す。

注¹⁾ A社情報システム部が運用している。利用者は、販売責任者、販売担当者などである。

注²⁾ Z販売課の課長1名だけである。

図1 受注管理業務の手順

〔Jシステムの操作権限〕

Z販売課では、Jシステムについて、次の利用方針を定めている。

〔方針1〕 ある利用者が入力した情報は、別の利用者が承認する。

〔方針2〕 販売責任者は、Z販売課の全業務の情報を閲覧できる。

Jシステムでは、業務上必要な操作権限を利用者に与える機能が実装されている。

この度、商品Zの受注管理業務が受注増によって増えていることから、B社に一部を委託することにした（以下、商品Zの受注管理業務の入力作業を行うB社従業員を商品ZのB社販売担当者といい、商品ZのB社販売担当者の入力結果をチェックするB社従業員を商品ZのB社販売責任者という）。

委託に当たって、Z 販売課は情報システム部に J システムに関する次の要求事項を伝えた。

〔要求 1〕 B 社が入力した場合は、A 社が承認する。

〔要求 2〕 A 社の販売担当者が入力した場合は、現状どおりに A 社の販売責任者が承認する。

上記を踏まえ、情報システム部は今後の各利用者に付与される操作権限を表 1 にまとめた。

表 1 操作権限案

利用者	付与される操作権限	J システム		
		閲覧	入力	承認
	a	○		○
	(省略)	○	○	
	(省略)	○		
	(省略)	○	○	

注記 ○は、操作権限が付与されることを示す。

設問 表 1 中の a に入れる適切な字句を解答群の中から選べ。

解答群

- ア Z 販売課の販売責任者
- イ Z 販売課の販売担当者
- ウ Z 販売課の要員
- エ 商品 Z の B 社販売責任者
- オ 商品 Z の B 社販売担当者

■ 3. 原题对应中文意思

问59 A 公司是拥有 200 名员工的通信邮购业者，面向普通消费者销售生活杂货、礼品等商品。其中一款经营商品——商品 Z，由 Z 销售课负责。

【Z 销售课的业务】

目前，Z 销售课的人员负责商品 Z 的受单管理业务及咨询应对业务。商品 Z 受单管理业务的流程如图1 所示。

图1 受单管理业务流程

商品 Z 的顾客订单通过电子邮件送达。

- (1) 录入：销售负责人将收到的订单（含变更、取消）内容录入受单管理系统^{注1)}（以下称“J 系统”），并向销售主管^{注2)}申请批准。
 - (2) 批准：销售主管核对订单内容与 J 系统录入结果，确认无误后予以批准；如有问题则退回。
- 注1) 由 A 公司信息系统部运营管理，使用者为销售主管、销售负责人等。
- 注2) 仅为 Z 销售课课长 1 人。

【J 系统的操作权限】

Z 销售课制定了如下关于 J 系统的使用方针：

[方针1] 由某一用户录入的信息，须由另一用户批准。

[方针2] 销售主管可查阅 Z 销售课全部业务的信息。

J 系统实现了按业务所需向用户授予相应操作权限的功能。此次，由于商品 Z 的受单管理业务因订单增加而增多，决定将其部分业务委托给 B 公司（以下将负责商品 Z 受单管理业务录入作业的 B 公司员工称为“商品 Z 的 B 公司销售负责人”，将负责核查商品 Z 的 B 公司销售负责人录入结果的 B 公司员工称为“商品 Z 的 B 公司销售主管”）。

在委托之际，Z 销售课向信息系统部提出了关于 J 系统的如下要求事项：

[要求1] 若由 B 公司录入，则由 A 公司进行批准。

[要求2] 若由 A 公司的销售负责人录入，则如现状一样由 A 公司的销售主管进行批准。

基于以上内容，信息系统部将今后各用户被授予的操作权限汇总为表1。

表1 操作权限方案

J 系统被授予的操作权限：浏览 录入 批准

用户：a ○ ○

用户：（省略，A 公司的销售负责人）○ ○

用户：（省略，商品 Z 的 B 公司销售负责人）○

用户：（省略，商品 Z 的 B 公司销售主管）○ ○

注记：○表示被授予该操作权限。

设问 表1 中 a 处应填入的恰当字句是下列哪一项？请从解答群中选出。

解答群

ア Z 销售课的销售主管（正确答案：表中该用户被授予“浏览”和“批准”权限，但没有“录入”权限。依据 [方针2]，销售主管可查阅 Z 销售课全部业务信息（对应“浏览”○）；依据 [要求1] 与 [要求2]，无论是 B 公司录入还是 A 公司销售负责人录入，最终都由 A 公司的销售主管（即 Z 销售课的销售主管）进行批准（对应“批准”○）；而销售主管本身并不参与订单录入工作（对应“录入”为空），因此该行对应的是“Z 销售课的销售主管”）

イ Z 销售课的销售负责人

ウ Z 销售课的人员

エ 商品 Z 的 B 公司销售主管

オ 商品 Z 的 B 公司销售负责人

問60 / 问题 60 (案例题)

■ 1. 重点单词 (日文 → English → 中文)

日文	English	中文
輸入食材	imported food ingredients	进口食材
商社	trading company	商社 (贸易公司)
経理課	accounting department	财务课 (会计部门)
海外子会社	overseas subsidiary	海外子公司
不審な点がある	have suspicious points	存在可疑之处
ヒアリング	interview / hearing	访谈
請求書	invoice	发票、请款单
送金先の口座	remittance destination account	汇款目的账户
早急に変更するよう求める	demand urgent change	要求尽快变更
テンプレート	template	模板
振込先	transfer destination	转账收款方
タイムゾーン	time zone	时区
ドメイン名	domain name	域名
類似するドメイン名	similar-looking domain name	近似域名
返信先 (Reply-To)	reply-to address	回复地址 (Reply-To)
フリーメール	free email service	免费邮箱
引用する	quote	引用
不正ログイン	unauthorized login	非法登录
設定変更	configuration change	设置变更
発覚を避ける	avoid detection	避免被发现
疑いをもたれないようにする	avoid arousing suspicion	避免被怀疑
手口	method / tactic	手法、手段

■ 2. 原题全文 (保留原卷排版/表格)

以下为 IPA 原题页面截图，表格与图示格式与原卷一致。

問60 A社は輸入食材を扱う商社である。ある日、経理課のB課長は、A社の海外子会社であるC社のDさんから不審な点がある電子メール（以下、メールという）を受信した。B課長は、A社の情報システム部に調査を依頼した。A社の情報システム部がC社の情報システム部と協力して調査した結果を図1に示す。

- 1 B課長へのヒアリング並びに受信したメール及び添付されていた請求書からは、次が確認された。

[項番1] Dさんが早急な対応を求めたことは今まで1回もなかったが、メール本文では送金先の口座を早急に変更するよう求めている。

[項番2] 添付されていた請求書は、A社がC社に支払う予定で進めている請求書であり、C社が3か月前から利用を開始したテンプレートを利用したものだった。

[項番3] 添付されていた請求書は、振込先が、C社が所在する国ではない国にある銀行の口座だった。

[項番4] 添付されていた請求書が作成されたPCのタイムゾーンは、C社のタイムゾーンとは異なっていた。

[項番5] メールを送信者（From）のメールアドレスには、C社のドメイン名とは別の類似するドメイン名が利用されていた。

[項番6] メールの返信先（Reply-To）はDさんのメールアドレスではなく、フリーメールのものであった。

[項番7] メール本文では、B課長とDさんとの間で6か月前から何度かやり取りしたメールの内容を引用していた。

2 不正ログインした者が、以降のメール不正閲覧の発覚を避けるために実施したと推察される設定変更がDさんのメールアカウントに確認された。

図1 調査の結果（抜粋）

設問 B課長に疑いをもたれないようにするためにメールの送信者が使った手口として考えられるものはどれか。図1に示す各項番のうち、該当するものだけを全て挙げた組合せを、解答群の中から選べ。

解答群

- | | |
|-----------------------|-----------------------|
| ア [項番1], [項番2], [項番3] | イ [項番1], [項番2], [項番6] |
| ウ [項番1], [項番4], [項番6] | エ [項番1], [項番4], [項番7] |
| オ [項番2], [項番3], [項番6] | カ [項番2], [項番5], [項番7] |
| キ [項番3], [項番4], [項番5] | ク [項番3], [項番5], [項番7] |
| ケ [項番4], [項番5], [項番6] | コ [項番5], [項番6], [項番7] |

■ 3. 原题对应中文意思

问60 A 公司是一家经营进口食材的商社。某日，财务课的 B 课长收到一封来自 A 公司海外子公司 C 公司的 D 先生发来的存在可疑之处的电子邮件（以下称“该邮件”）。B 课长请求 A 公司信息系统部进行调查。A 公司信息系统部与 C 公司信息系统部协作调查的结果如图1 所示。

图1 调查结果（节选）

1 通过对 B 课长的访谈，以及收到的邮件及其所附发票，确认了以下情况：

[项号1] D 先生以往从未有过要求紧急处理的情况，但此次邮件正文要求尽快变更汇款账户。

[项号2] 所附发票是 A 公司准备支付给 C 公司的发票，使用的是 C 公司 3 个月前开始启用的模板。

[项号3] 所附发票中的转账收款方，是位于并非 C 公司所在国家的一家银行的账户。

[项号4] 制作该发票所用 PC 的时区，与 C 公司的时区不同。

[项号5] 邮件发件人（From）的邮箱地址，使用的是与 C 公司域名不同但相似的域名。

[项号6] 邮件的回复地址（Reply-To）并非 D 先生本人的邮箱地址，而是一个免费邮箱地址。

[项号7] 邮件正文引用了 B 课长与 D 先生之间 6 个月前开始的多次往来邮件内容。

2 在 D 先生的邮箱账户中，发现了推测为非法登录者为避免邮件被非法查阅一事日后被发觉，而进行的设置变更。

设问 为了不让 B 课长产生怀疑，邮件发送者所使用的手法，考虑起来可能是下列图1 所示各项号中的哪些？请从解答群中选出全部包含相符项号的组合。

解答群

ア [项号1]，[项号2]，[项号3]

イ [项号1]，[项号2]，[项号6]

ウ [项号1]，[项号4]，[项号6]

エ [项号1]，[项号4]，[项号7]

オ [项号2]，[项号3]，[项号6]

カ [项号2]，[项号5]，[项号7]（正确答案：为了不让 B

课长起疑，攻击者会刻意采用能让邮件看起来“逼真、正常”的手段——[项号2] 使用 C

公司近期真实启用的发票模板，使发票外观与真实文件几乎一致；[项号5] 使用与 C

公司域名极为相似的伪造域名作为发件人地址，使 B 课长不易察觉发件人有异；[项号7] 在邮件正文中引用此前双方真实的历史邮件往来内容，营造“确实是在继续以往对话”的可信氛围。这三项均是主动用于伪装、消除怀疑的手法。而 [项号1]（异常紧急的要求）、[项号3]（境外陌生账户）本身反而容易引起怀疑；[项号4]（制作设备时区）、[项号6]（Reply-To 地址）属于事后调查中才发现的技术痕迹，并非 B 课长在收信当下能够察觉、也不是发送者刻意用来消除怀疑的手法）

キ [项号3]，[项号4]，[项号5]

ク [项号3]，[项号5]，[项号7]

ケ [项号4]，[项号5]，[项号6]

コ [项号5]，[项号6]，[项号7]